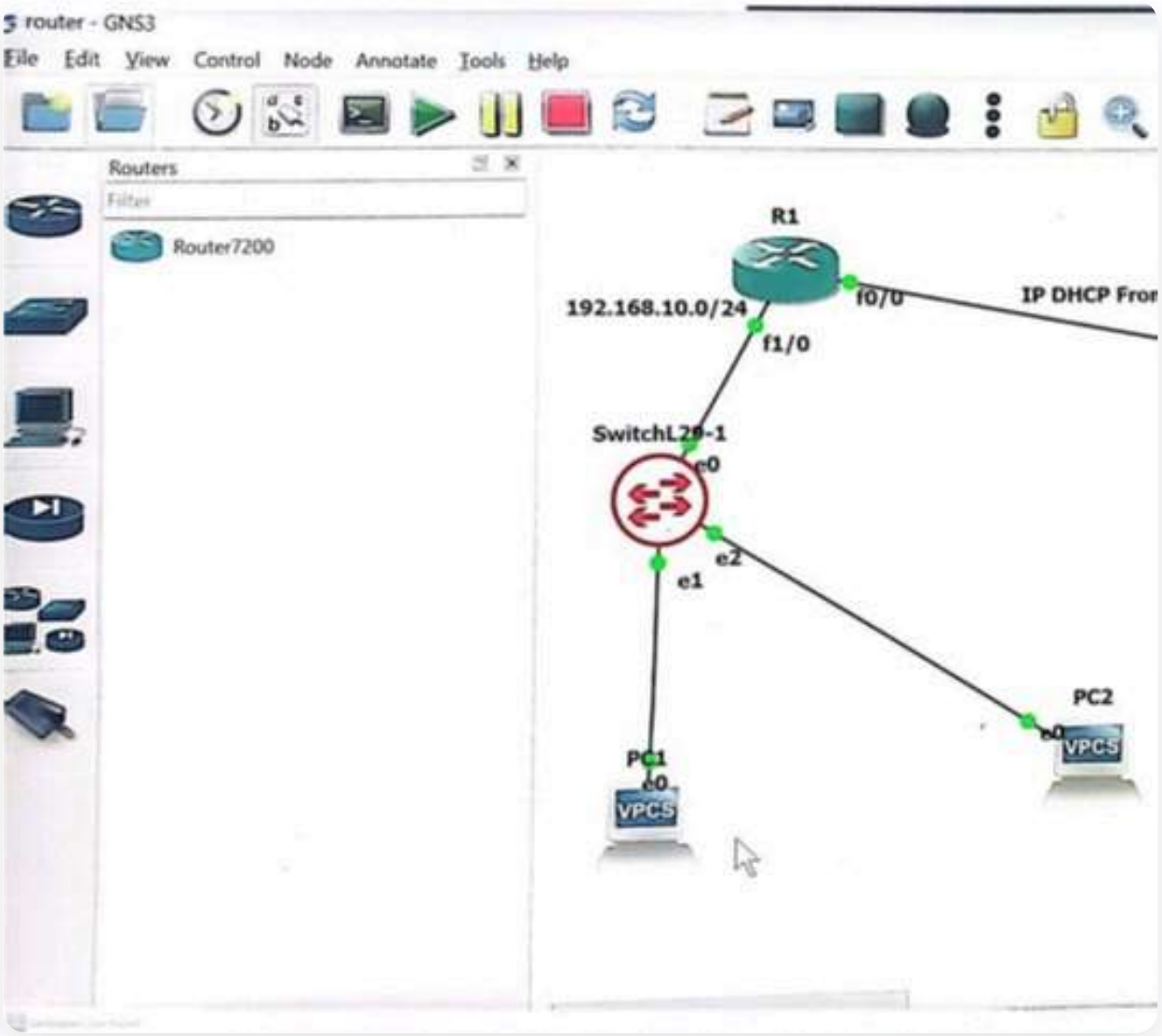
تامين السويتش



السؤال الثاني: تأمين السويتش (SwitchL2-1)

لديك سويتش SwitchL2-1 يربط بين الراوتر (R1) وجهازي (PC1, PC2) PC.

السويتش معرض لهجمات الطبقة الثانية مثل MAC Flooding, VLAN Hopping, ARP Spoofing, DHCP Starvation.

المطلوب:

قم بتأمين السويتش بشكل كامل وعملي ضد جميع الهجمات المحتملة، مع كتابة الأوامر، شرح كل خطوة، وذكر أوامر العرض للتحقق.

الهجمات التي قد يتعرض لها السويتش:

1. هجمات MAC Flooding (إغراق جدول CAM)
2. هجمات VLAN Hopping (Double Tagging / Switch Spoofing)
3. هجمات ARP Spoofing (انتحال ARP)
4. هجمات DHCP Starvation (تجويع DHCP)
5. هجمات استغلال STP (Spanning Tree Protocol)
6. هجمات CDP/LLDP (جمع المعلومات)

المطلوب:

(1) تأمين الوصول إلي السويتش (SSH & Management)

- قم بتعيين عنوان IP للإدارة على VLAN 1: 192.168.10.2/24
- قم بتعيين بوابة افتراضية default-gateway (192.168.10.1)
- قم بتأمين الوصول إلى السويتش عبر SSH بنفس إعدادات الراوتر (مفتاح RSA 4096 بت، مستخدم محلي، ACL، مهلة، محاولات).
- أوامر العرض: اكتب الأمر المستخدم لعرض إعدادات SSH ، والمستخدمين المتصلين، والـ ACL

(2) حماية منافذ المستخدمين (Port Security)

- قم بتفعيل Port Security على منافذ PCs بحيث:
- يسمح بجهاز واحد فقط (maximum 1)

- يتم إيقاف المنفذ عند الانتهاك (violation shutdown)
- يتم حفظ عنوان MAC المتعلم (mac-address sticky)
- قم بتفعيل Port Fast و BPDU Guard على منافذ PCs.
- أوامر العرض: اكتب الأمر المستخدم لعرض حالة Port Security ، والأمر المستخدم لعرض حالة المنافذ بما فيها errdisable

(3) منع هجمات VLAN Hopping

- قم بتعطيل DTP على منافذ المستخدمين: switchport mode access و switchport nonegotiate
- قم بتغيير Native VLAN على Trunk إذا كان موجوداً إلي VLAN غير مستخدم مثل 999
- قم تحديد VLANS المسموح بها على Trunk (switchport trunk allowed vlan)
- أوامر العرض: اكتب الأمر المستخدم لعرض Trunk و Native VLAN ، والأمر المستخدم لعرض VLANS المسموح بها.

(4) منع هجمات ARP و DHCP

- قم بتفعيل DHCP Snooping لمنع خوادم DHCP المارقة وتجويع العناوين:
- فعل DHCP Snooping عالمياً وعلى VLAN 1
- عين منفذ Uplink المتصل بـ R1 كـ trusted
- فعل rate limit على منافذ المستخدمين مثل 15 حزمة في الثانية
- قم بتفعيل Dynamic ARP Inspection (DAI) لمنع انتحال ARP:
- فعل DAI على VLAN 1
- عين منفذ Uplink كـ trusted لـ DAI
- أوامر العرض: اكتب الأمر المستخدم لعرض حالة DHCP Snooping وجدول الربط، والأمر المستخدم لعرض حالة DAI وإحصائياته.

(5) منع هجمات STP

- قم بتفعيل BPDU Guard على منافذ المستخدمين لمنع هجمات STP
- قم بتفعيل Root Guard على منفذ Uplink لمنع السويتش من أن يصبح Root
- أوامر العرض: اكتب الأمر المستخدم لعرض حالة STP و BPDU Guard

(6) إيقاف الخدمات غير الضرورية على السويتش:

- قم بإيقاف CDP عالمياً (no cdp run)
- قم بإيقاف LLDP إذا كان مفعلاً
- أوامر العرض: اكتب الأمر المستخدم لعرض حالة CDP

(7) تفعيل التسجيل (Logging) على السويتش

- قم بتفعيل التسجيل على السويتش بنفس إعدادات الراوتر (تسجيل محاولات الدخول، الطوابع الزمنية، إرسال إلي Syslog).
- أوامر العرض: اكتب الأمر المستخدم لعرض سجل الأحداث.

(8) اختبار التأمين (من كالي)

- قم باختبار هجوم MAC Flooding (macof) وراقب تأثير Port Security
- قم باختبار هجوم DHCP Starvation (dhcpstarv) وراقب تأثير DHCP Snooping
- قم باختبار هجوم ARP Spoofing (arpspoof) وراقب تأثير DAI
- أوامر الاختبار: كتابة أوامر الهجوم من كالي والنتائج المتوقعة

تأمين السويتش SwitchL2-1

تم تطبيق إعدادات حماية السويتش ضد هجمات الطبقة الثانية، وتشمل تأمين Port Security ،SSH، منع VLAN Hopping، حماية DHCP وARP، حماية STP، وإيقاف الخدمات غير الضرورية، مع تنفيذ أوامر التحقق والاختبار.

---

(1)تامين الوصول الى السويتش (SSH & Management)

تامين الوصول والادارة

```
configure terminal

! 1. إعداد عنوان IP للإدارة والبوابة الافتراضية
interface vlan 1
ip address 192.168.10.2 255.255.255.0
no shutdown
exit
ip default-gateway 192.168.10.1

! 2. إعداد اسم الجهاز والـ Domain
hostname SwitchL29-1
ip domain-name lab.local

! 3. إنشاء حساب مستخدم محلي بصلاحيات كاملة
username admin privilege 15 secret AdminPass123

! 4. إنشاء مفتاح تشفير RSA بطول 4096-bit
crypto key generate rsa modulus 4096

! 5. إنشاء قائمة وصول ACL لتحديد الأجهزة المسموح لها بالإدارة عبر SSH
ip access-list extended ACL_SSH_MGMT
permit tcp 192.168.10.0 0.0.0.255 any eq 22
exit

! 6. تطبيق إعدادات SSH وحماية خطوط VTY (مهلة ومحاولات الاتصال)
ip ssh version 2
ip ssh time-out 60
ip ssh authentication-retries 3
```

```
line vty 0 15
transport input ssh
login local
access-class ACL_SSH_MGMT in
exec-timeout 5 0
exit

end
```

حماية الشاملة ضد هجمات الطبقة الثانية

```
configure terminal

! — أ. الحماية من هجمات MAC Flooding (تحديد عدد العناوين المسموح بها) —
interface range FastEthernet 0/1 – 24
switchport mode access
switchport port-security
switchport port-security maximum 2
switchport port-security violation restrict
switchport port-security mac-address sticky
exit

! — ب. الحماية من هجمات VLAN Hopping (تعطيل DTP وتحديد VLAN الصريحة) —
interface range FastEthernet 0/1 – 24
switchport mode access
switchport nonegotiate
exit

! — ج. الحماية من هجمات DHCP Starvation (DHCP Snooping) —
ip dhcp snooping
ip dhcp snooping vlan 1
```

```
! تحديد المافذ الموثوقة (المتصلة بالراوتر أو خادم DHCP)
interface GigabitEthernet 0/1
ip dhcp snooping trust
exit

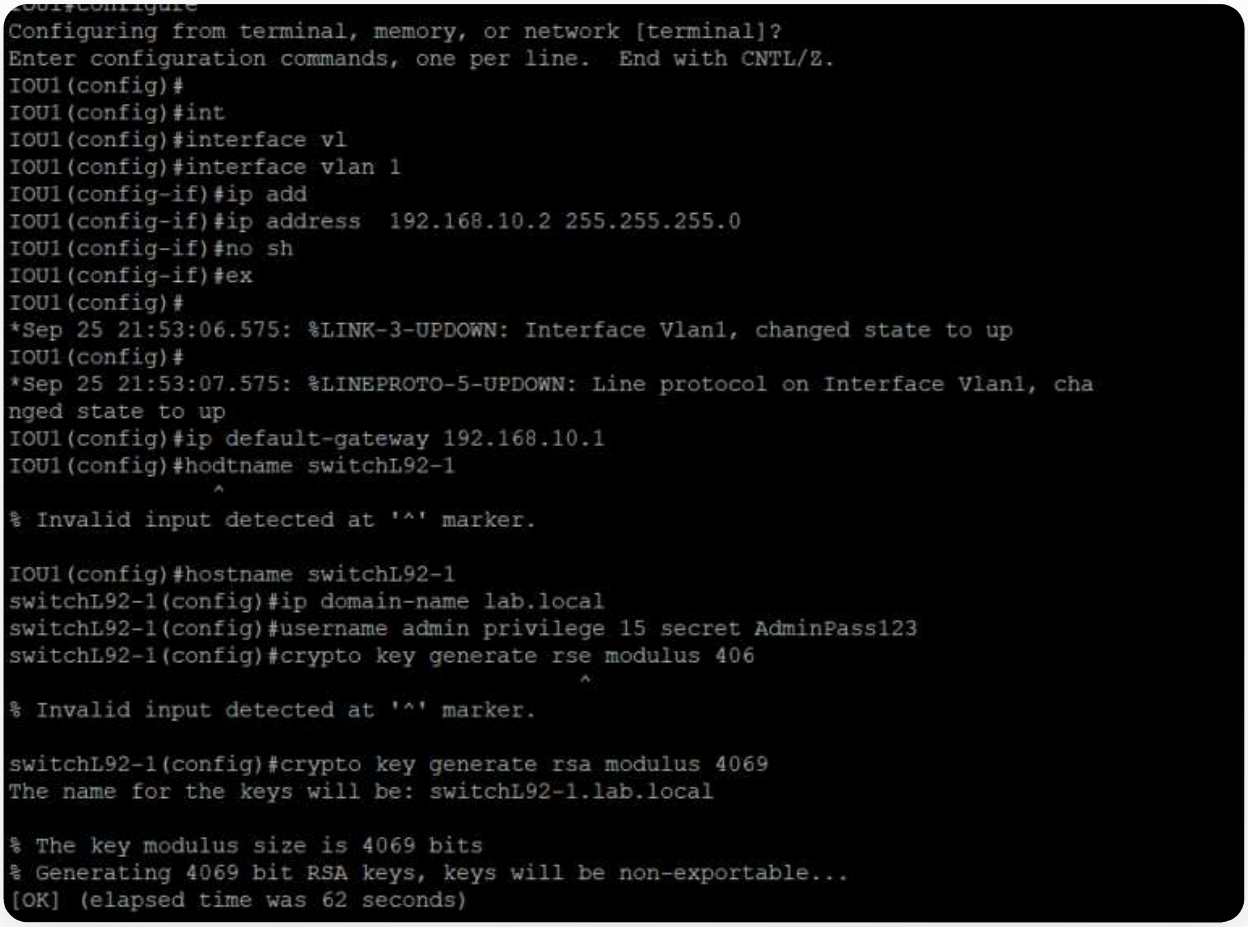
! — د. الحماية من هجمات ARP Spoofing (Dynamic ARP Inspection – DAI) —
ip arp inspection vlan 1
interface GigabitEthernet 0/1
ip arp inspection trust
exit

! — هـ. الحماية من هجمات STP (BPDU Guard & PortFast) —
interface range FastEthernet 0/1 – 24
spanning-tree portfast
spanning-tree bpduguard enable
exit

! — و. الحماية من هجمات الاستكشاف جمع المعلومات (CDP / LLDP) —
! تعطيل CDP و LLDP على المنافذ المواجهة للمستخدمين (Access Ports)
interface range FastEthernet 0/1 – 24
no cdp enable
no lldp transmit
no lldp receive
exit

! — ز. تأمين المنافذ غير المستخدمة (Shutdown & Native VLAN Isolation) —
! يفضل حظر المنافذ غير المستخدمة وحسابياً وضعها في VLAN معزولة
interface range FastEthernet 0/10 – 24
shutdown
exit
```

end



عرض المستخدمين المتصلين حالياً عبر SSH/Console:

show users

عرض إعدادات وحالة SSH:

show ip ssh

عرض قائمة الوصول ACL الإدارية:

show ip access-lists ACL_SSH_MGMT

```
switchL92-1#
switchL92-1#show ip ssh
SSH Enabled - version 2.0
Authentication timeout: 60 secs; Authentication retries: 3
Minimum expected Diffie Hellman key size : 1024 bits
IOS Keys in SECSH format(ssh-rsa, base64 encoded):
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAAB/RhdcWLmAFtjQbzww4sY3AtWuqjPUQEeCTWefVXMx/TE
7U4E5NLgfO/xGDAszy61X6vVgHQh5O0Lm0g9hPJJQKICe7whPBD13qtXgXEVczAUm3UoJDdl+AHUYALJ
FxSIEPLRFYqRb8uDSx0acchfvYwD65iYASF2M5lHypvO2msN6oG1BO12Y/QsdLM3c91ZyBvO8JVqk5ke
IQWh+j1oZBN45EoVIYkN3s0184dPdDOSUsa5f7G51x7TRggDUf6kGQqgztSqhG3F85xIZq/861/2DLZ5
YME2dkS9RjXopjy9LfmH4avWJWUiVm+cqV+utut/BwAJX13qR46PuSfalBH1uI77/zfzMJhEhznEgWZ+
S5US8w5msAtIiYK6+ocnYq6U9zw3Qsz8HCoHdRDcrtbIyLtM0InCd0RhL9Z6/iJ4MIWtaNKrIoUQne3D
Raq2D8RPbtHg2I07ZmxNrqZPHs34HstvDLP4zjwv3OGeQy+Zyoe5YTg+KnnSn+EbPl1FjLR6cIs15ysn
T9RmyuaWbzTv6/8wZVGnQMnMrJPw+2QLixF9yYK1//mI0+2SbFdyQ7tkZPXpBYdOo9odmTvT6T4Coofz
J5t5xL4RvunLdxXnpoBGBCwdKGLacSCr4v0Shx7Zuua1WoVi1J38hyyEhLhxoZuQ9TCzgRlvJp6v
switchL92-1#show users
    Line       User       Host(s)              Idle       Location
*  0 con 0                idle                 00:00:00

  Interface    User               Mode         Idle     Peer Address

switchL92-1#show ip access-lists ACL_SSH_MGMT
Extended IP access list ACL_SSH_MGMT
    10 permit tcp 192.168.10.0 0.0.0.255 any eq 22
switchL92-1#
```

(2)حماية منافذ المستخدمين

```
switchL92-1#configure
Configuring from terminal, memory, or network [terminal]?
Enter configuration commands, one per line.  End with CNTL/Z.
switchL92-1(config)#
switchL92-1(config)#int
switchL92-1(config)#interface range et
switchL92-1(config)#interface range ethernet 0/1 - 2
switchL92-1(config-if-range)#sw
switchL92-1(config-if-range)#switchport m
switchL92-1(config-if-range)#switchport mode a
switchL92-1(config-if-range)#switchport mode access
switchL92-1(config-if-range)#sw
switchL92-1(config-if-range)#switchport o
switchL92-1(config-if-range)#switchport p
switchL92-1(config-if-range)#switchport po
switchL92-1(config-if-range)#switchport port-security
switchL92-1(config-if-range)#switchport port-security m
switchL92-1(config-if-range)#switchport port-security ma
switchL92-1(config-if-range)#switchport port-security max
switchL92-1(config-if-range)#switchport port-security maximum 1
switchL92-1(config-if-range)#switchport port-security vi
switchL92-1(config-if-range)#switchport port-security violation sh
switchL92-1(config-if-range)#switchport port-security violation shutdown
switchL92-1(config-if-range)#switchport port-security mac
switchL92-1(config-if-range)#switchport port-security mac-address dt
switchL92-1(config-if-range)#switchport port-security mac-address st
switchL92-1(config-if-range)#switchport port-security mac-address sticky
switchL92-1(config-if-range)#sp
switchL92-1(config-if-range)#spanning-tree port
switchL92-1(config-if-range)#spanning-tree portfast
%Warning: portfast should only be enabled on ports connected to a single
 host. Connecting hubs, concentrators, switches, bridges, etc... to this
 interface  when portfast is enabled, can cause temporary bridging loops.
 Use with CAUTION

%Portfast will be configured in 3 interfaces due to the range command
 but will only have effect when the interfaces are in a non-trunking mode.
switchL92-1(config-if-range)#spa
switchL92-1(config-if-range)#spanning-tree bpdu
switchL92-1(config-if-range)#spanning-tree bpduguard en
switchL92-1(config-if-range)#spanning-tree bpduguard enable
switchL92-1(config-if-range)#exit
switchL92-1(config)#end
switchL92-1#
*Sep 25 22:14:28.035: %SYS-5-CONFIG_I: Configured from console by console
switchL92-1#
```

```
configure terminal

! تحديد منافذ الأجهزة e1 و e2 (ملاحظة: إذا كانت المنافذ FastEthernet استخدم fa0/1 – 2)
interface range Ethernet 0/1 – 2

! تحويل المنافذ إلى وضع Access
switchport mode access

! 1. تفعيل Port Security
switchport port-security

! 2. تحديد السماح بجهاز واحد فقط (Maximum 1)
switchport port-security maximum 1

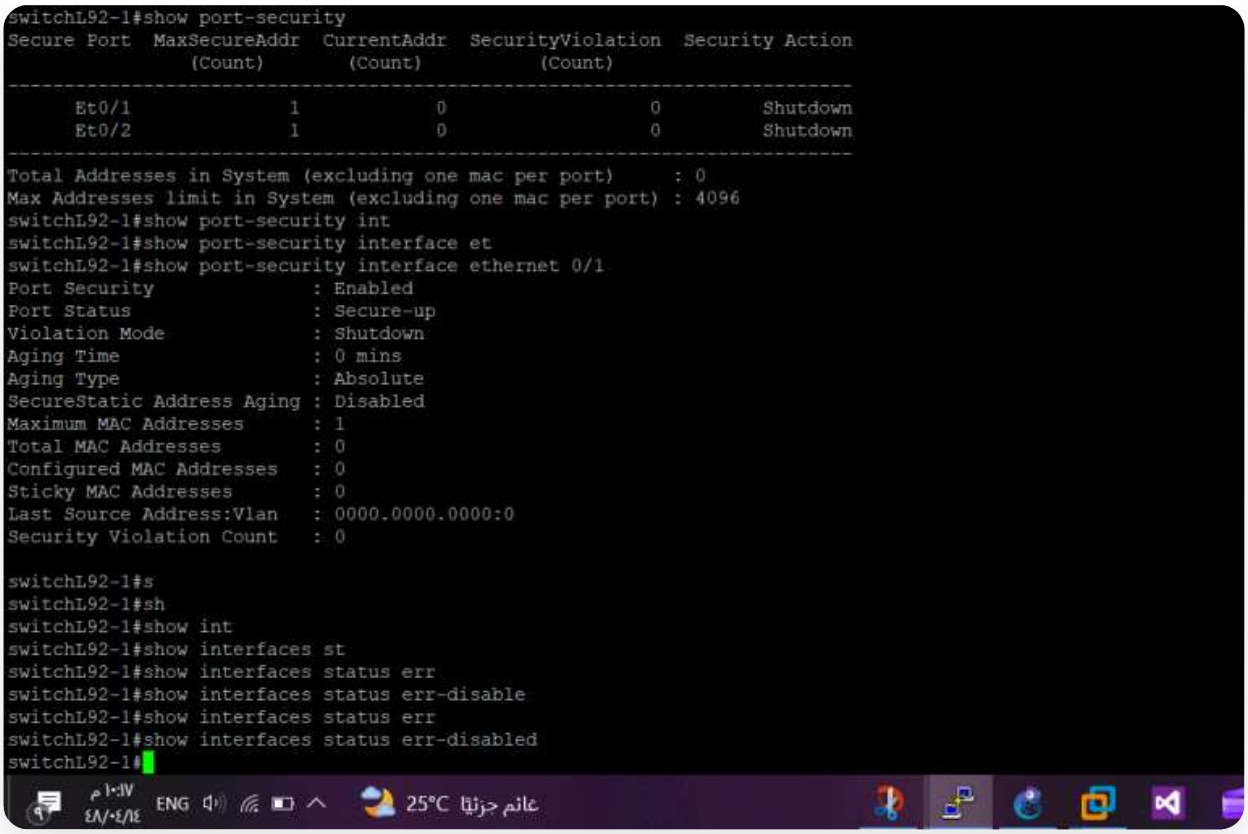
! 3. ضبط نمط الانتهاك لإغلاق المنفذ (Violation Shutdown)
switchport port-security violation shutdown

! 4. حفظ عنوان MAC المتعلم تلقائياً (MAC Address Sticky)
switchport port-security mac-address sticky

! 5. تفعيل PortFast للانتقال السريع للوضع النشط
spanning-tree portfast

! 6. تفعيل BPDU Guard لحماية المنفذ من أجهزة STP
spanning-tree bpduguard enable

exit
end
```



عرض حالة Port Security الإجمالية وعلى مستوى المنافذ:

show port-security

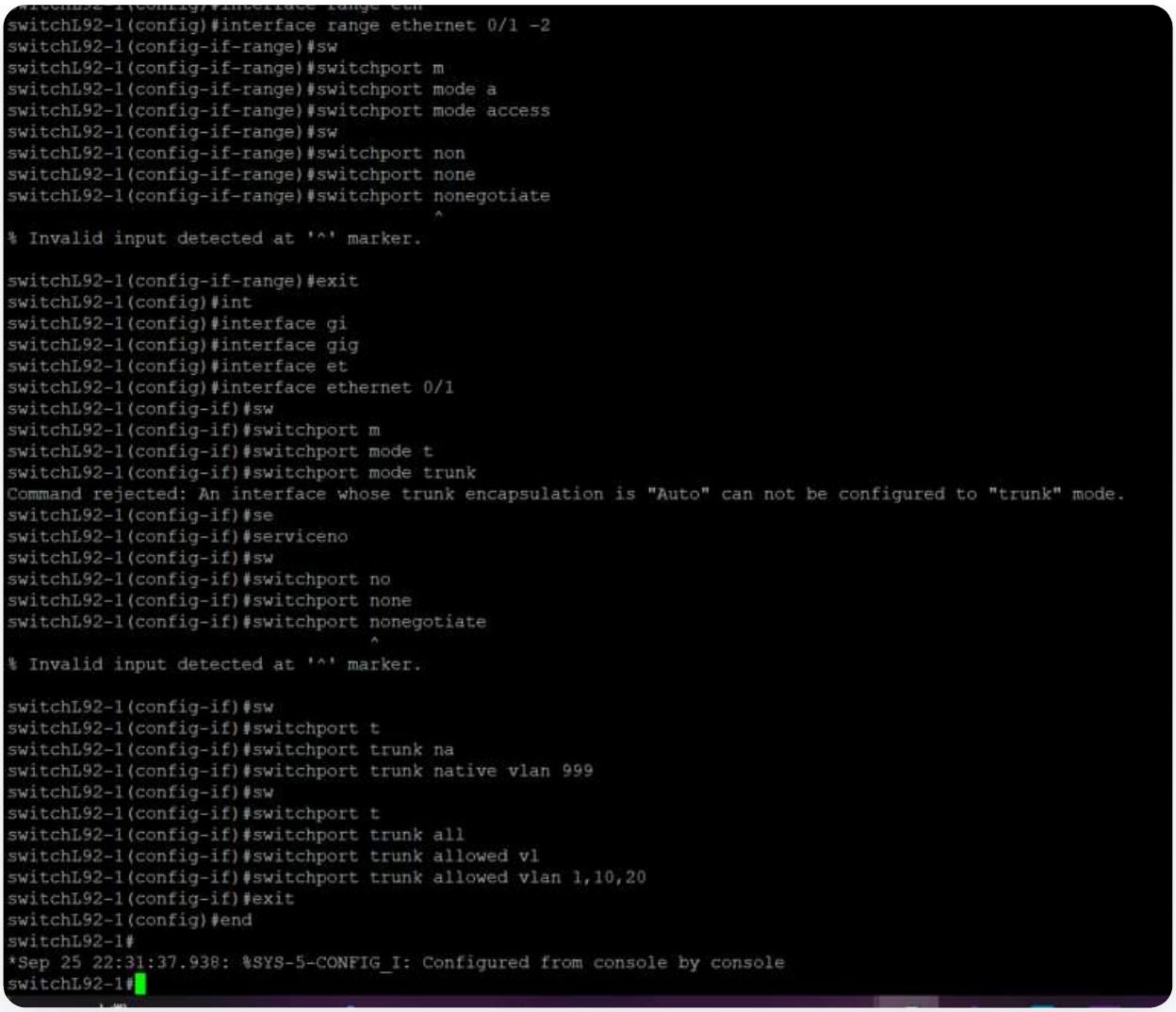
show port-security interface Ethernet 0/1

عرض حالة المنافذ المعطلة بسبب الانتهاكات الأمنية (بما فيها errdisable):

show interfaces status err-disable

---

(3)منع هجمات VLAN Hopping



configure terminal

! — أ. تعطيل DTP وتحديد النمط الصريح على منافذ المستخدمين (Access Ports) —

interface range Ethernet 0/1 – 2

switchport mode access

switchport nonegotiate

exit

! — ب. إعداد منفذ Trunk وتغيير Native VLAN وتحديد الـ VLANs المسموح بها —

! (افترضنا أن المنفذ الموصل بالراوتر أو بسويتش آخر هو GigabitEthernet 0/1)

interface GigabitEthernet 0/1

switchport mode trunk

switchport nonegotiate

! تغيير Native VLAN إلى رقم غير مستخدم (مثلاً 999)

switchport trunk native vlan 999

! تحديد الـ VLANs المسموح بمرورها فقط عبر الترانك

switchport trunk allowed vlan 1,10,20

exit

end

عرض حالة منفذ الـ Trunk و الـ Native VLAN الخاصة به:

show interfaces trunk

عرض الـ VLANs المسموح بها تفصيلياً على منفذ معين (مثلاً e0/1 أو gi0/1):

show interfaces GigabitEthernet 0/1 switchport

---

(4)منع هجمات DHCP & ARP

```
switchL92-1(config)#ip dhcp snooping
switchL92-1(config)#ip dhcp snooping vl
switchL92-1(config)#ip dhcp snooping vlan 1
switchL92-1(config)#int
switchL92-1(config)#interface gi
switchL92-1(config)#interface et
switchL92-1(config)#interface ethernet 0/1
switchL92-1(config-if)#ip dhcp sn
switchL92-1(config-if)#ip dhcp snooping t
switchL92-1(config-if)#ip dhcp snooping trust
switchL92-1(config-if)#exit
switchL92-1(config)#int
switchL92-1(config)#interface ra
switchL92-1(config)#interface range et
switchL92-1(config)#interface range ethernet 0/1 -2
switchL92-1(config-if-range)#ip dh
switchL92-1(config-if-range)#ip dhcp  sn
switchL92-1(config-if-range)#ip dhcp  snooping li
switchL92-1(config-if-range)#ip dhcp  snooping limit ra
switchL92-1(config-if-range)#ip dhcp  snooping limit rate 15
switchL92-1(config-if-range)#exit
```

```
configure terminal

! — أ. إعداد وتفعيل DHCP Snooping —
! تفعيل الخدمة عالمياً وعلى مستوى VLAN 1
ip dhcp snooping
ip dhcp snooping vlan 1

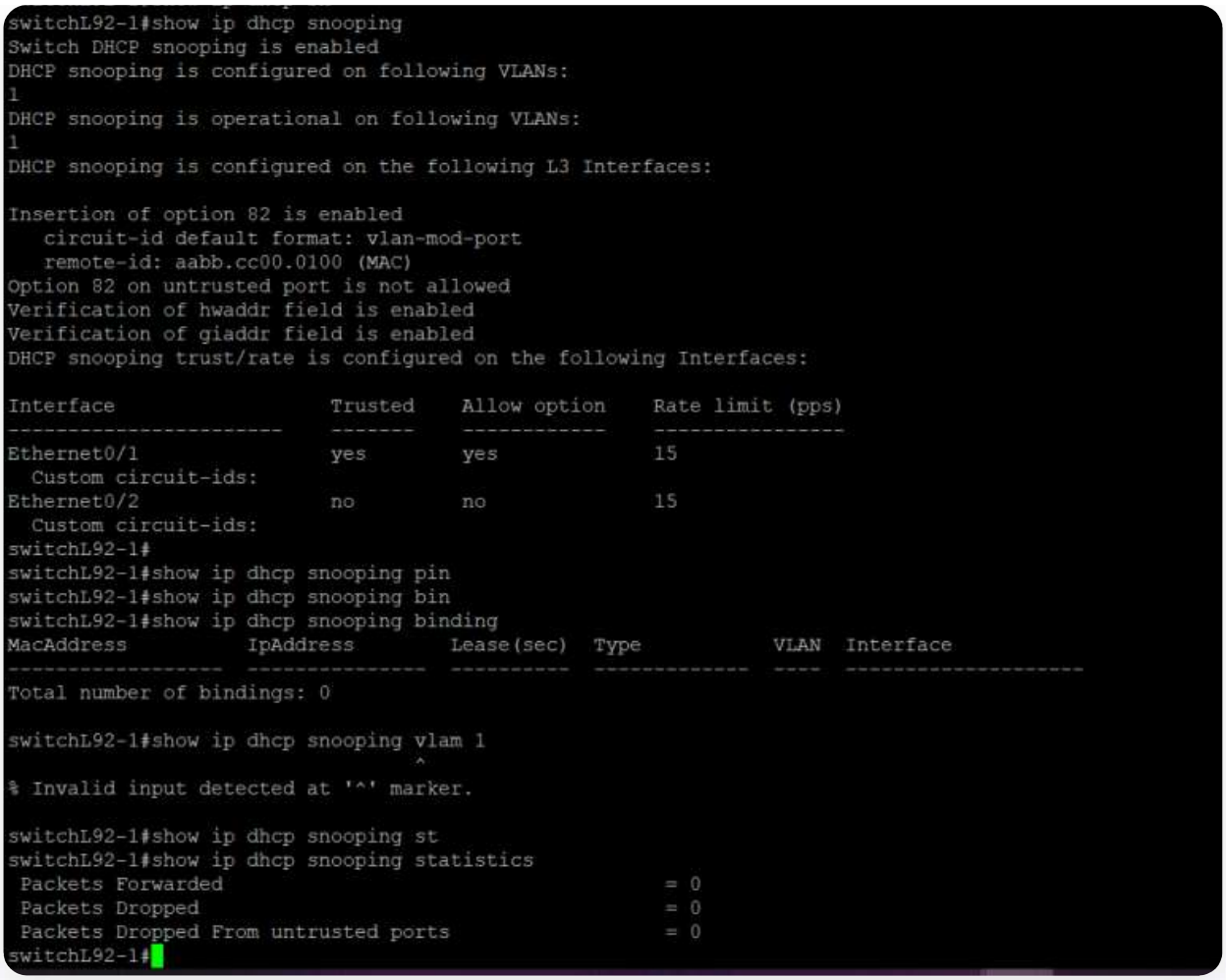
! تحديد منفذ الـ Uplink المتصل بالراوتر R1 كموثوق (Trusted)
interface GigabitEthernet 0/1
ip dhcp snooping trust
exit

! تحديد معدل الحزم (Rate Limit) على منافذ المستخدمين لمنع هجمات DHCP Starvation
interface range Ethernet 0/1 – 2
ip dhcp snooping limit rate 15
exit

! — ب. إعداد وتفعيل Dynamic ARP Inspection (DAI) —
! تفعيل DAI على مستوى VLAN 1
ip arp inspection vlan 1

! تحديد منفذ الـ Uplink الموصل بالراوتر R1 كموثوق (Trusted) لـ DAI
interface GigabitEthernet 0/1
ip arp inspection trust
exit

end
```



عرض حالة إعدادات DHCP Snooping العامة والمنافذ:

show ip dhcp snooping

عرض جدول ربط العناوين المتعلمة بواسطة DHCP Snooping (Binding Table):

show ip dhcp snooping binding

عرض حالة وتفاصيل إعدادات Dynamic ARP Inspection (DAI):

show ip arp inspection vlan 1

عرض إحصائيات DAI والحزم المقبولة/المرفوضة:

show ip arp inspection statistics

---

(5)منع هجمات STP

```
switchL92-1(config)#interface range ethernet 0/1 - 2
switchL92-1(config-if-range)#sp
switchL92-1(config-if-range)#spanning-tree bp
switchL92-1(config-if-range)#spanning-tree bpdug
switchL92-1(config-if-range)#spanning-tree bpduguard en
switchL92-1(config-if-range)#spanning-tree bpduguard enable
switchL92-1(config-if-range)#exit
switchL92-1(config)#int
switchL92-1(config)#interface e
switchL92-1(config)#interface et
switchL92-1(config)#interface ethernet 0/0
switchL92-1(config-if)#sp
switchL92-1(config-if)#spanning-tree g
switchL92-1(config-if)#spanning-tree guard r
switchL92-1(config-if)#spanning-tree guard root
switchL92-1(config-if)#ex
*Sep 25 22:44:26.552: %SPANTREE-2-ROOTGUARD_CONFIG_CHANGE: Root guard enabled on port Ethernet0/0.
switchL92-1(config-if)#exit
switchL92-1(config)#
```

configure terminal

! — أ. تفعيل BPDU Guard على منافذ المستخدمين (Access Ports) —

interface range Ethernet 0/1 – 2

spanning-tree bpduguard enable

exit

! — ب. تفعيل Root Guard على منفذ الـ Uplink المتصل بالراوتر R1 —

interface GigabitEthernet 0/1

spanning-tree guard root

exit

end

```
switchL92-1#show spanning-tree inconsistentports

Name                 Interface              Inconsistency
-------------------- ---------------------- ------------------

Number of inconsistent ports (segments) in the system : 0

switchL92-1#
switchL92-1#
```

عرض حالة بروتوكول Spanning Tree الإجمالية والشجرة الحالية:

show spanning-tree

عرض حالة المنافذ المفعّل عليها BPDU Guard وتأكيد تفعيله:

show spanning-tree summary

عرض المنافذ التي تم إيقافها بسبب استقبال حزم BPDU غير مصرح بها:

show interfaces status err-disable

عرض المنافذ التي تم تقييدها بواسطة Root Guard (في حالة اكتشاف محاولة سيطرة على الـ Root):

show spanning-tree inconsistentports

---

(6)ايقاف الخدمات الغير ضرورية على السويتش



configure terminal

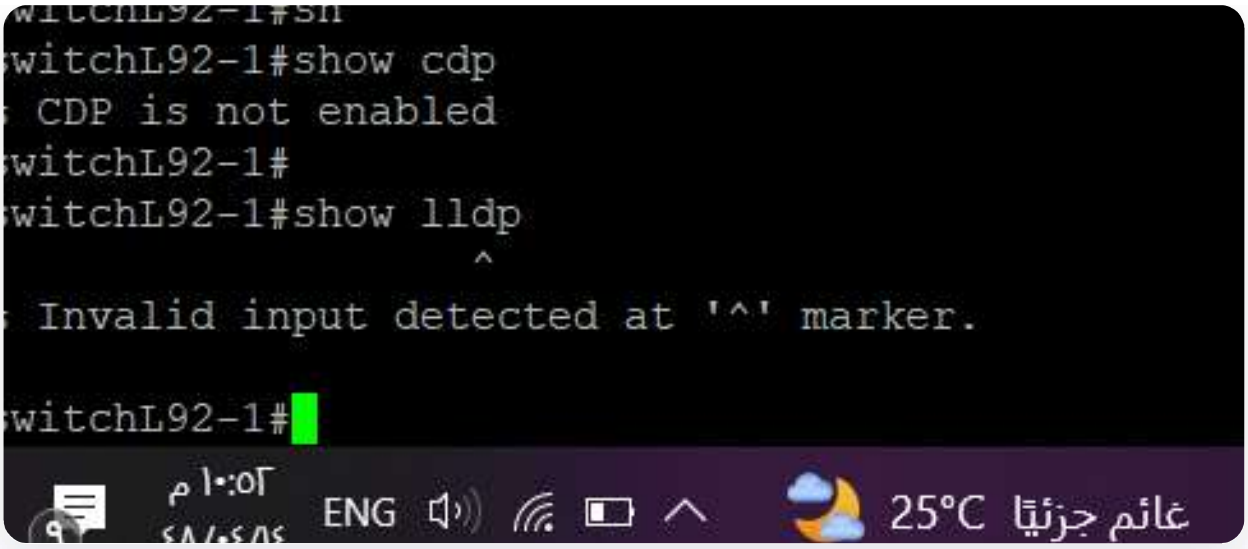
! — أ. إيقاف بروتوكول CDP عالمياً —

no cdp run

! — ب. إيقاف بروتوكول LLDP عالمياً —

no lldp run

end



عرض حالة CDP الإجمالية للتأكد من تعطيله:

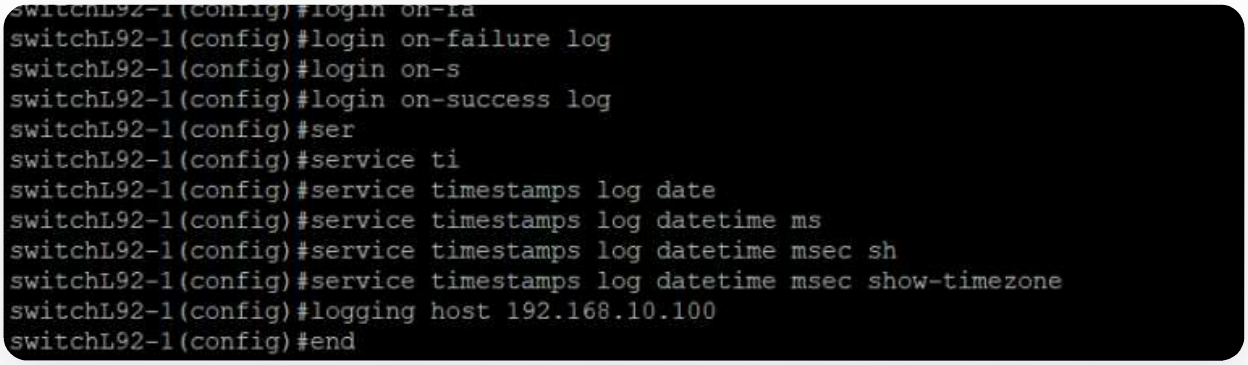
show cdp

عرض حالة LLDP الإجمالية للتأكد من تعطيله:

show lldp

---

(7)تفعيل التسجيل Logging على السوتش



configure terminal

! أ. حجز ذاكرة مؤقتة لتخزين الأحداث داخل السويتش بحجم 4096 بايت

logging buffered 4096

! ب. تسجيل محاولات الدخول الناجحة والفاشلة إلى السويتش

login on-failure log

login on-success log

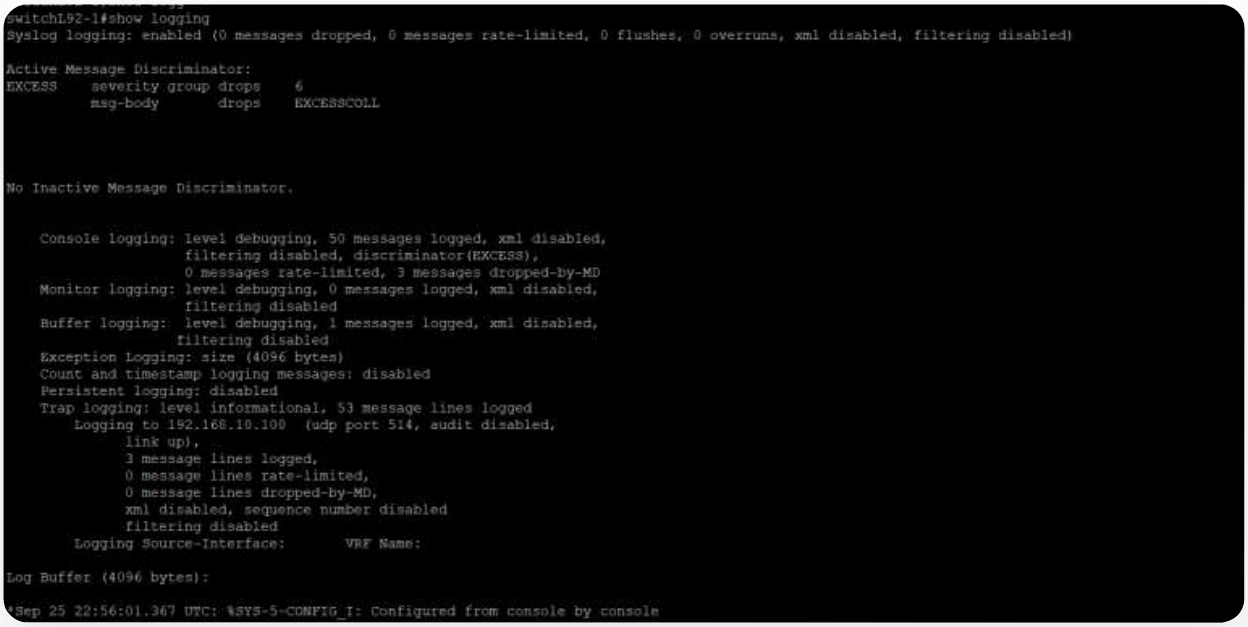
! ج. تفعيل الطوابع الزمنية الدقيقة (بالتاريخ والوقت والأجزاء من الثانية) للسجلات

service timestamps log datetime msec show-timezone

! د. إرسال سجلات الأحداث تلقائياً إلى خادم Syslog المباشر (مثل IP 192.168.10.100)

logging host 192.168.10.100

end



الأمر المستخدم لعرض سجل الأحداث المخزنة في الذاكرة:

show logging

---

(8)اختبار التامين (من كالي)

اختبار هجوم إغراق جدول CAM (MAC Flooding Attack)

sudo macof -i eth1

طريقة المراقبة من السويتش (SwitchL29-1#):

show port-security interface FastEthernet 0/1

show mac address-table count

النتيجة المتوقعة:

قام خيار Port Security بتحديد الحد الأقصى لعناوين MAC المسموح بها (مثلاً 2 عناوين)، وبالتالي سيقوم السويتش بإسقاط جميع الحزم الواردة ذات العناوين العشوائية المنتحلة وزيادة عداد الانتهاكات (SecurityViolation) دون أن يتم إغراق جدول CAM أو التأثير على حركة المرور الشرعية.

اختبار هجوم تجويع العناوين (DHCP Starvation Attack

sudo yersinia dhcp -attack 1 -i eth1

طريقة المراقبة من السويتش (SwitchL29-1#):

show ip dhcp snooping

show ip dhcp snooping statistics

تقوم ميزة DHCP Snooping بفرض حد أعلى لعدد الطلبات (rate limit 15 حزمة/ثانية)، مما يؤدي إلى حظر وإسقاط الفيضان الهائل من طلبات DHCP المزيفة القادمة من منفذ المستخدم، مما يمنع نفاذ العناوين من خادم DHCP ويحمي الشبكة.

اختبار هجوم انتحال ARP (ARP Spoofing Attack

sudo arpspoof -i eth1 -t 192.168.10.1 192.168.10.2

طريقة المراقبة من السويتش (SwitchL29-1#):

show ip arp inspection statistics

تعتمد تقنية Dynamic ARP Inspection (DAI) على مطابقة استجابات ARP القادمة من جهاز كالي مع جدول dhcp snooping binding. وبما أن عنوان IP/MAC غير مسجل ومطابق في الجدول، سيقوم السويتش فوراً بإسقاط ردود ARP المزيفة (Invalid ARP packets dropped) ويفشل المهاجم في تنفيذ هجوم الوسيط (Man-in-the-Middle

وصف

تم التحقق العملي من متانة حماية الطبقة الثانية (Layer 2) بالسويتش؛ حيث نجح نظام الدفاع المدمج في إحباط محاولات استنزاف الذاكرة عبر macof بفضل Port Security، كما حيّد هجمات تعطيل توزيع العناوين من خلال DHCP Snooping، وأفشل محاولات اعتراض واختطاف البيانات عبر تقنية Dynamic ARP Inspection (DAI).

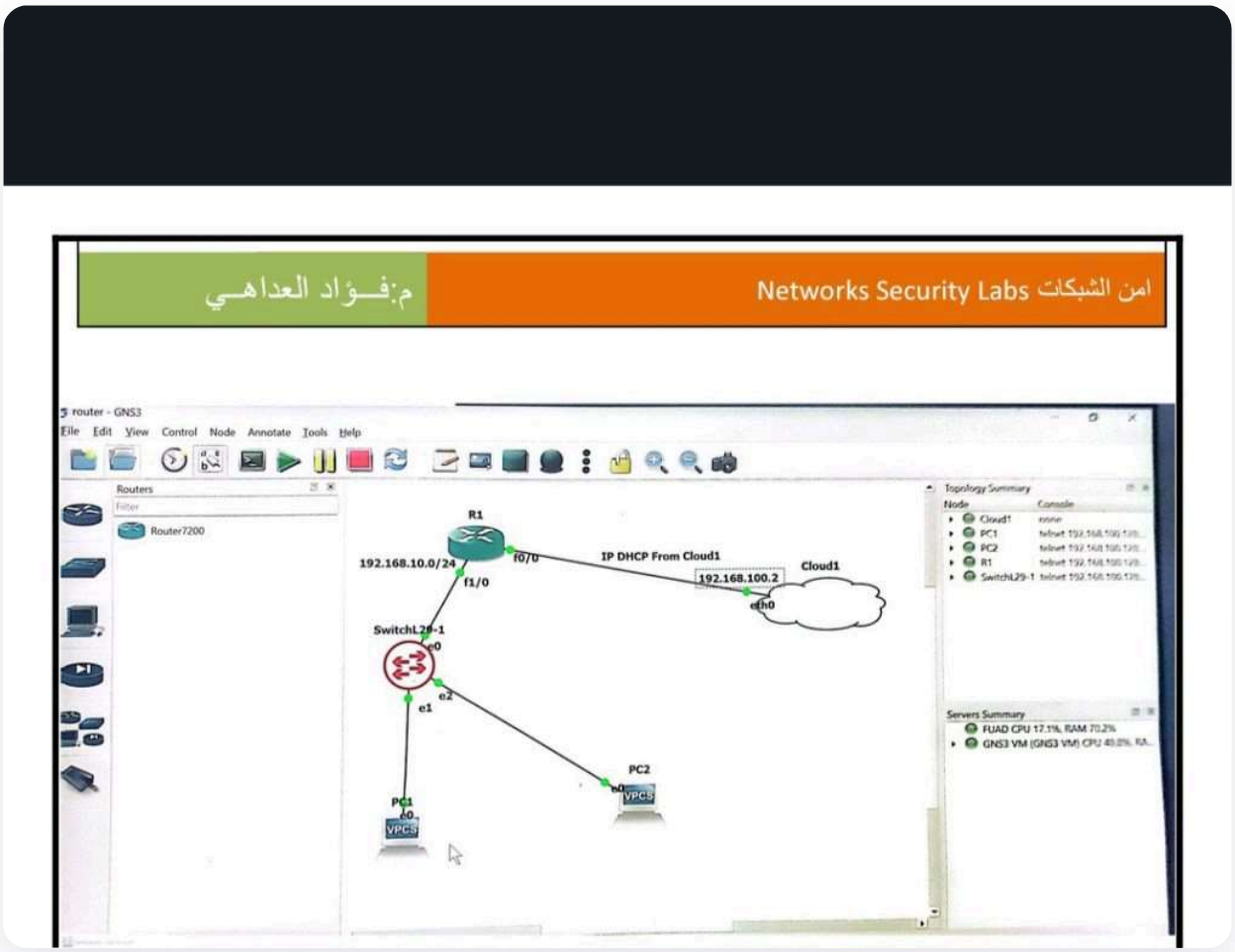
امن شبكات

توثيق المشاريع والتطبيقات العملية

المدونة حول الأسئلة المتكررة المؤلفون

الفعاليات متجر الأنماط القوالب

تامين الراوتر



السؤال الأول على الراوتر (R1)

لديك راوتر (1) متصل بالإنترنت عبر Cloud 1 واجهة 0/0 ومتصل بشبكتك الداخلية عبر واجهة 1/0 الراوتر، قم بتوصيل الشبكة التي بالصورة بحيث يصل البنج من كالي الي الـ pcs والعكس صحيح.

الراوتر معرض لهجمات متعددة مثل هجمات القوة العمياء على SSH ، هجمات DoS على المعالج، هجمات انتحال العناوين، واستغلال الخدمات غير الضرورية.

المطلوب:

قم بتأمين الراوتر بشكل كامل وعملي ضد جميع الهجمات المحتملة، مع كتابة الأوامر، شرح كل خطوة، وذكر أوامر العرض للتحقق.

الهجمات التي قد يتعرض لها الراوتر:

1. هجمات القوة العمياء (Brute force) على SSH
2. هجمات DoS على المعالج (Control Plane)
3. هجمات انتحال العناوين (IP Spoofing)
4. هجمات استغلال الخدمات غير الضرورية مثل (HTTP, CDP, Finger)
5. هجمات اعتراض حركة المرور (MITM) عبر ARP Spoofing
6. هجمات استغلال SNMP إذا كان مفعلا
7. هجمات استهداف الواجهات مثل (ICMP Redirect, Proxy ARP)

المطلوب:

(1) تأمين الوصول إلي الراوتر (SSH & Management)

- قم بإيقاف Telnet وتفعيل SSH الإصدار 2 فقط.
- أنشئ مفتاح RSA بطول 4096 بت.
- أنشئ مستخدم محلي (admin) بصلاحية كاملة (privilege 15) وكلمة مرور مشفرة باستخدام أقوى خوارزمية (scrypt).
- قم بتقييد الوصول إلي SSH بحيث يسمح فقط لعناوين IP في 192.168.100.0/24
- حدد مهلة المصادقة (60) ثانية وعدد المحاولات الفاشلة (3).
- أوامر العرض: اكتب الأمر المستخدم لعرض إعدادات SSH ، والمستخدمين المتصلين، والـ ACL

(2) إيقاف الخدمات غير الضرورية

- قم بايقاف الخدمات غير الضرورية (HTTP, CDP, Finger, PAD, Source Routing).
- اشرح سبب إيقاف كل خدمة.
- أوامر العرض: اكتب الأمر المستخدم لعرض الخدمات التي تم إيقافها.

(3) تأمين الواجهات:

قم بتأمين الواجهة الخارجية (g0/0) والداخلية (g1/0) عن طريق:

- منع ICMP Redirect
- منع Proxy ARP
- منع رسائل "الوجهة غير قابلة للوصول".
- منع البث الموجه (Directed Broadcast)
- منع الرد على طلبات قناع الشبكة.
- إيقاف CDP على الواجهات.
- قم بتفعيل (uRPF Strict Mode) على الواجهة الخارجية (g0/0) لمنع انتحال العناوين.
- أوامر العرض: اكتب الأمر المستخدم لعرض حالة الواجهة وتأكيد التغييرات، والأمر المستخدم لعرض حالة uRPF

(4) حماية (Control Plane (CoPP

قم بحماية الراوتر من هجمات DoS التي تستهدف المعالج عن طريق:

1. إنشاء ACL لتصنيف حركة ICMP
2. إنشاء Class-Map
3. إنشاء Policy-Map باسم COPP بحيث يحد من حركة ICMP بمعدل 8000 بت في الثانية.
4. تطبيق السياسة على Control Plane العام (control-plane)
5. قم بإضافة حماية لحركة SSH على Control Plane باستخدام control-plane host

- أوامر العرض: اكتب الأمر المستخدم لعرض إحصائيات COPP ، والأمر المستخدم لعرض تفاصيل Policy-Map

(5) تفعيل التسجيل (Logging) والمراقبة

قم بتفعيل نظام التسجيل على الراوتر بحيث:

- يتم تخزين السجلات في الذاكرة بحجم 4096 بايت.
- يتم تسجيل كل محاولة دخول فاشلة وناجحة.
- يتم إضافة طابع زمني مع التاريخ والوقت لرسائل السجل.
- يتم إرسال السجلات إلى خادم Syslog خارجي (اختر أي عنوان IP).
- أوامر العرض: اكتب الأمر المستخدم لعرض سجل الأحداث، والأمر المستخدم لعرض إعدادات Syslog

(6) تأمين SNMP إذا كان مفعلا

إذا كنت تستخدم SNMP ، قم بتأمينه باستخدام SNMPv3 مع مصادقة (auth) وتشفير (priv).

- أنشئ مجموعة (group) ومستخدم (user) مع كلمات مرور قوية.
- قم بتقييد الوصول إلي SNMP بحيث يسمح فقط لعناوين IP محددة.
- أوامر العرض: اكتب الأمر المستخدم لعرض مستخدمي SNMP ، والأمر المستخدم لعرض إعدادات SNMP

(7) اختبار التأمين (من كالي)

أوامر الاختبار: كتابة أوامر الهجوم من كالي والنتائج المتوقعة.

قم باختبار SSH:

اتصال ناجح من عنوان مسموح.

اتصال مرفوض من عنوان غير مسموح.

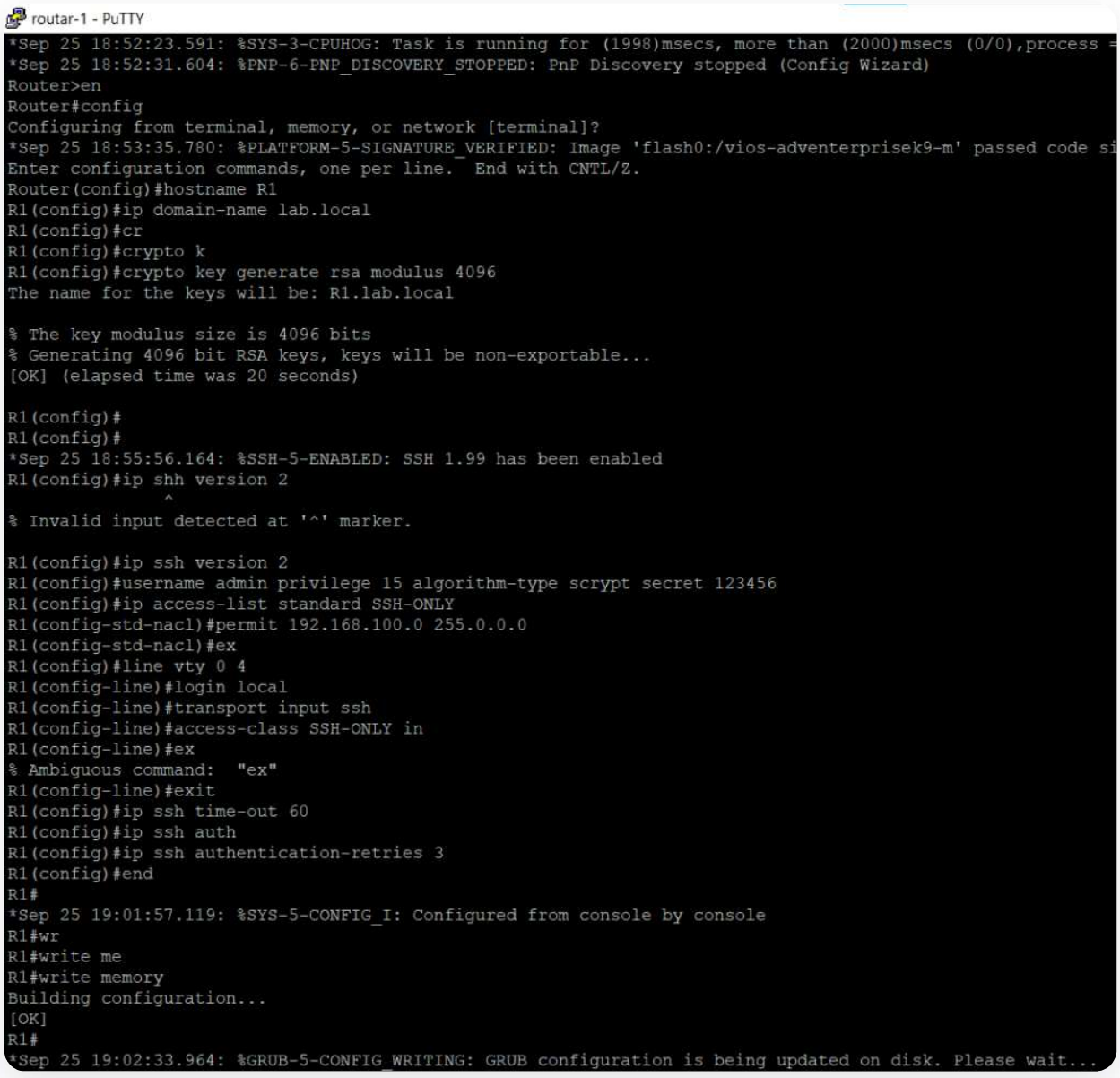
محاولة 3 مرات بكلمة مرور خاطئة.

قم باختبار هجوم ICMP Flood (hping3) وراقب تأثير COPP

قم باختبار هجوم SSH Brute Force (hydra) وراقب تأثير authentication-retries

يهدف هذا النشاط إلى تأمين الراوتر ضد الهجمات المحتملة، وتشمل حماية SSH، إيقاف الخدمات غير الضرورية، تأمين الواجهات، حماية Control Plane باستخدام CoPP، تفعيل التسجيل والمراقبة، وتأمين SNMP عند استخدامه.

سيتم توثيق كل خطوة بالأوامر المستخدمة، وشرح مختصر، وأوامر التحقق، وصور التنفيذ والنتائج.



enable

configure terminal

```
! اسم الراوتر والدومين
hostname R1
ip domain-name lab.local

! إنشاء مفتاح RSA بطول 4096 بت
crypto key generate rsa modulus 4096

! تفعيل SSH الإصدار 2 فقط
ip ssh version 2

! إنشاء المستخدم admin بصلاحية 15 وتشفير Scrypt
username admin privilege 15 algorithm-type scrypt secret 123456

! ACL للسماح فقط للشبكة 192.168.100.0/24
ip access-list standard SSH-ONLY
permit 192.168.100.0 0.0.0.255
exit

! السماح بـ SSH فقط ومنع Telnet
line vty 0 4
login local
transport input ssh
access-class SSH-ONLY in
exit

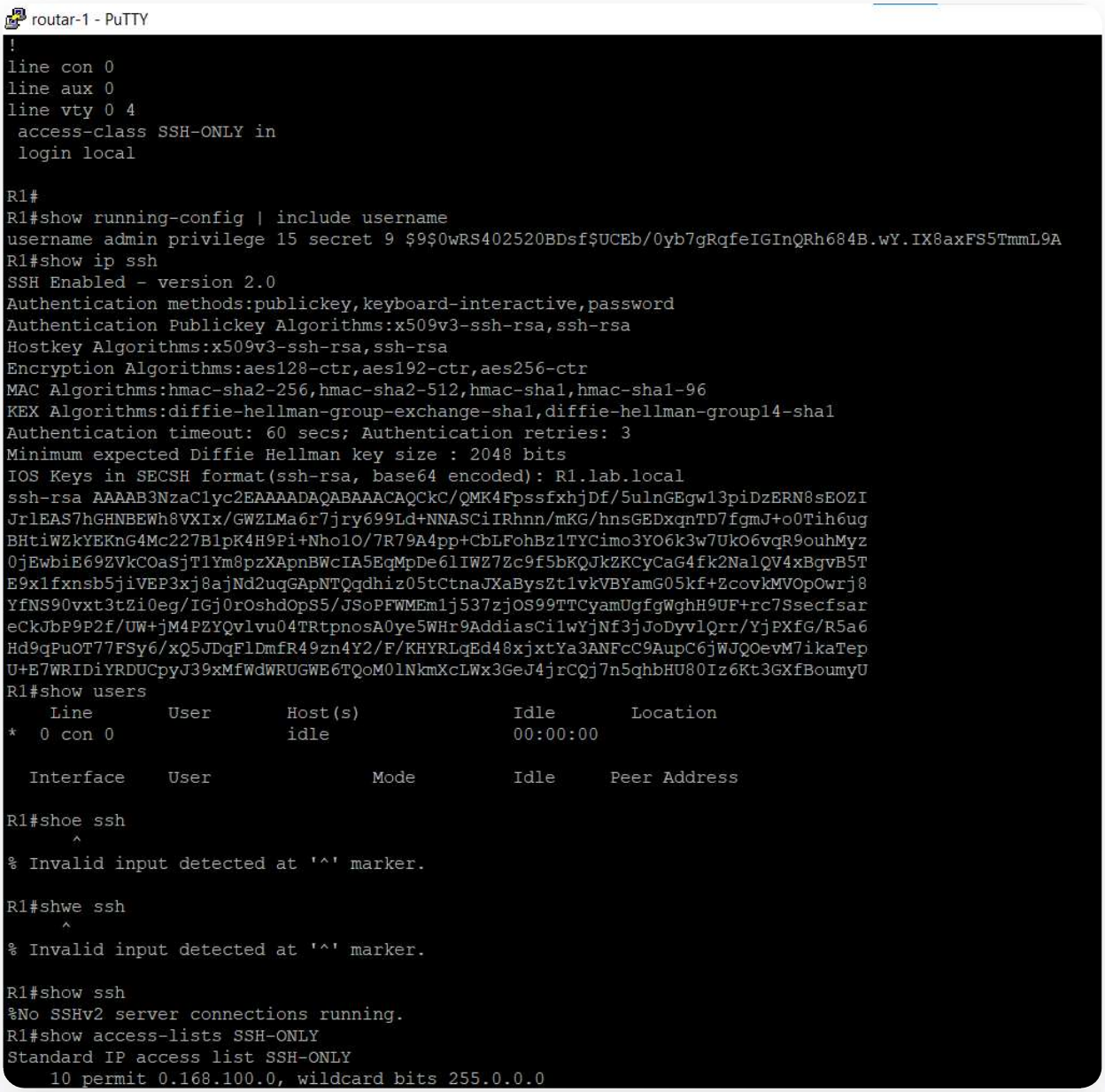
! مهلة SSH = 60 ثانية
ip ssh time-out 60

! السماح بـ 3 محاولات فاشلة
ip ssh authentication-retries 3

end
```

! حفظ الإعدادات

write memory



العرض

! عرض المستخدم المحلي

show running-config | include username

! عرض إعدادات SSH

show ip ssh

! عرض المستخدمين المتصلين

show users

! عرض جلسات SSH الحالية

show ssh

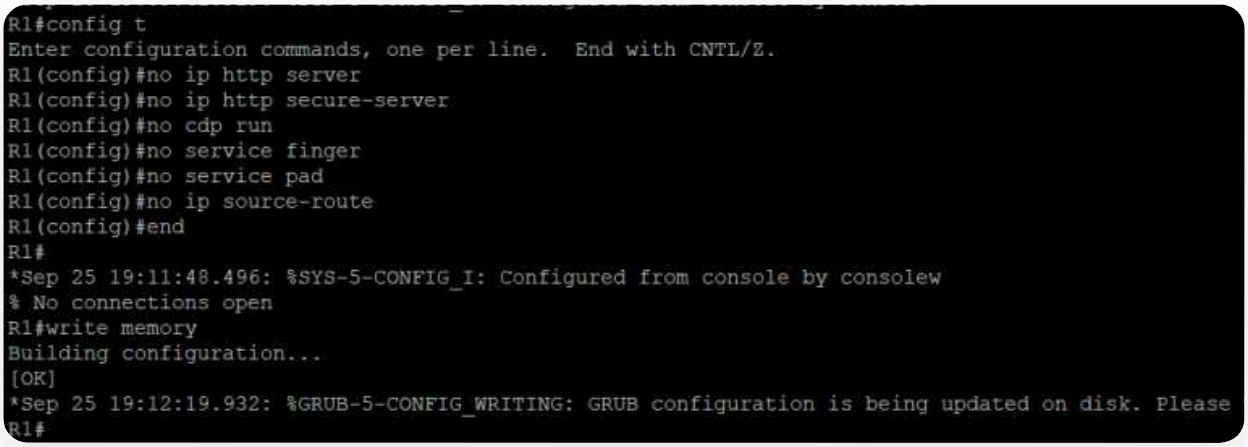
! عرض ACL الخاصة بالسماح لـ SSH

show access-lists SSH-ONLY

وصف

تم تأمين الوصول إلى الراوتر بإيقاف Telnet وتفعيل SSHv2 فقط، وإنشاء مفتاح RSA بطول 4096 بت، وإنشاء مستخدم Admin بصلاحية 15، وتقييد SSH على شبكة 192.168.100.0/24، مع تحديد مهلة 60 ثانية و3 محاولات فاشلة، ثم التحقق من الإعدادات باستخدام أوامر العرض

ايقاف الخدمات



enable

configure terminal

! إيقاف HTTP

no ip http server

no ip http secure-server

! إيقاف CDP

no cdp run

! إيقاف Finger

no service finger

! إيقاف PAD

no service pad

! إيقاف IP Source Routing

no ip source-route

end

write memory

سبب ايقاف كل خدمة

:HTTP

إيقاف واجهة إدارة الراوتر عبر HTTP/HTTPS غير الضرورية وتقليل سطح الهجوم.

:CDP

إيقافه لمنع كشف معلومات الأجهزة والواجهات المجاورة.

:Finger

إيقافه لمنع كشف معلومات عن المستخدمين والخدمات.

:PAD

إيقاف خدمة PAD القديمة غير الضرورية وتقليل الخدمات المتاحة للمهاجم.

:IP Source Routing

إيقافه لمنع الحزم من تحديد مسارها عبر الشبكة وتجنب بعض أساليب تجاوز التوجيه.

```
R1#show running-config | include ip http
no ip http server
no ip http secure-server
R1#show running-config | include ip cdp
R1#show running-config | include cdp
no cdp run
R1#show running-config | include service finger
R1#show running-config | include service pad
no service pad
R1#show running-config | include ip source-route
no ip source-route
R1#
```

اومر العرض_لتاكد من الخدمات

show running-config | include ip http

show running-config | include cdp

show running-config | include service finger

show running-config | include service pad

show running-config | include ip source-route

الوصف

تم إيقاف الخدمات غير الضرورية HTTP وCDP وFinger وPAD وIP Source Routing لتقليل سطح الهجوم ومنع كشف معلومات غير ضرورية عن الراوتر والشبكة، ثم تم التحقق من حالة الخدمات بأوامر العرض وحفظ الإعدادات.

تامين الواجهات

```
R1(config-if)#interface gigabitEthernet 0/0
R1(config-if)#no ip redirects
R1(config-if)#no ip proxy-arp
R1(config-if)#no ip unreachables
R1(config-if)#no ip directed-broadcast
R1(config-if)#no ip mask-reply
R1(config-if)#no cdp enable
R1(config-if)#ip verify unicast source reachable-via rx
R1(config-if)#exit
```

```
R1(config)#interface gigabitEthernet 0/1
R1(config-if)#no ip redirects
R1(config-if)#no ip proxy-arp
R1(config-if)#no ip unreachables
R1(config-if)#no ip directed-broadcast
R1(config-if)#no ip mask-reply
R1(config-if)#no cdp enable
R1(config-if)#exit
```

عدداة الواجهة الخارجية 0/0

R1# configure terminal

R1(config)# interface GigabitEthernet0/0

R1(config-if)# no ip redirects

! تعطيل إرسال إعادة توجيه ICMP لمنع إعادة توجيه حزم البيانات لمسارات غير مصرح بها

R1(config-if)# no ip proxy-arp

! تعطيل الـ Proxy ARP لمنع هجمات الاستطلاع والتنصت Man-in-the-Middle

R1(config-if)# no ip unreachables

! تعطيل إرسال رسائل "الوجهة غير قابلة للوصول" لمنع هجمات استكشاف الشبكة مسح المنافذ

R1(config-if)# no ip directed-broadcast

! تعطيل البث الموجه لمنع استغلال الراوتر في هجمات Smurf DoS

R1(config-if)# no ip mask-reply

! تعطيل الرد على طلبات استعلام قناع الشبكة لحماية معلومات تقسيم الشبكة Subnetting

R1(config-if)# no cdp enable

! تعطيل بروتوكول اكتشاف Cisco لمنع تسريب معلومات جهاز الراوتر للجيران

R1(config-if)# ip verify unicast source reachable-via rx

! تفعيل حماية uRPF بوضع Strict للتحقق من أن مصدر الحزمة يطابق جدول التوجيه لنفس الواجهة لمنع انتحال العناوين (IP Spoofing)

R1(config-if)# exit

الواجهة الداخلية0/1

R1(config)# interface GigabitEthernet1/0

R1(config-if)# no ip redirects

! منع إرسال رسائل ICMP Redirect داخل الشبكة المحلية

R1(config-if)# no ip proxy-arp

! منع الواجهة من الاستجابة لطلبات ARP بالنيابة عن أجهزة أخرى

R1(config-if)# no ip unreachables

! إخفاء حالة المنافذ المغلقة عن الفحص الداخلي

R1(config-if)# no ip directed-broadcast

! منع حزم البث الموجه القادمة من الشبكة المحلية

R1(config-if)# no ip mask-reply

! منع إعطاء معلومات قناع الشبكة للعملاء

R1(config-if)# no cdp enable

! إيقاف بروتوكول CDP على الواجهة الداخلية

R1(config-if)# exit

```
R1#show ip interface gigabitEthernet0/0
GigabitEthernet0/0 is administratively down, line protocol is down
  Internet protocol processing disabled
R1#show ip interface gigabitEthernet0/1
GigabitEthernet0/1 is administratively down, line protocol is down
  Internet protocol processing disabled
R1#show ip traffic
IP statistics:
  Rcvd:  0 total, 0 local destination
         0 format errors, 0 checksum errors, 0 bad hop count
         0 unknown protocol, 0 not a gateway
         0 security failures, 0 bad options, 0 with options
  Opts:  0 end, 0 nop, 0 basic security, 0 loose source route
         0 timestamp, 0 extended security, 0 record route
         0 stream ID, 0 strict source route, 0 alert, 0 cipso, 0 ump
         0 other
  Frags: 0 reassembled, 0 timeouts, 0 couldn't reassemble
         0 fragmented, 0 fragments, 0 couldn't fragment
         0 invalid hole
  Bcast: 0 received, 18 sent
  Mcast: 0 received, 0 sent
  Sent:  18 generated, 0 forwarded
  Drop:  0 encapsulation failed, 0 unresolved, 0 no adjacency
         0 no route, 0 unicast RPF, 0 forced drop
         0 options denied
  Drop:  0 packets with source IP address zero
  Drop:  0 packets with internal loop back IP address
         0 physical broadcast
  Reinj: 0 in input feature path, 0 in output feature path

ICMP statistics:
  Rcvd: 0 format errors, 0 checksum errors, 0 redirects, 0 unreachable
        0 echo, 0 echo reply, 0 mask requests, 0 mask replies, 0 quench
        0 parameter, 0 timestamp, 0 timestamp replies, 0 info request, 0 other
        0 irdp solicitations, 0 irdp advertisements
        0 time exceeded, 0 info replies
  Sent: 0 redirects, 0 unreachable, 0 echo, 0 echo reply
        0 mask requests, 0 mask replies, 0 quench, 0 timestamp, 0 timestamp replies
        0 info reply, 0 time exceeded, 0 parameter problem
        0 irdp solicitations, 0 irdp advertisements

UDP statistics:
  Rcvd: 0 total, 0 checksum errors, 0 no port 0 finput
  Sent: 18 total, 0 forwarded broadcasts

BGP statistics:
  Rcvd: 0 total, 0 opens, 0 notifications, 0 updates
        0 keepalives, 0 route-refresh, 0 unrecognized
 --More--
```

عرض خالة الواجهة

R1# show ip interface GigabitEthernet0/0

لعرض حالة ميزة uRPF

R1# show ip traffic

الوصف

قمنا بتقليل مساحة الهجوم (Attack Surface) على راوتر R1 من خلال تعطيل الخدمات والبروتوكولات غير الضرورية والمعرضة للاستغلال على الواجهتين الخارجية والداخلية (مثل ICMP و CDP و Proxy ARP) لمنع عمليات الاستكشاف والتجسس. كما قمنا بتفعيل تقنية Unicast Reverse Path Forwarding (uRPF) بوضع Strict Mode على الواجهة الخارجية، والتي تجبر الراوتر على مطابقة عنوان المصدر للحزم الواردة مع جدول التوجيه الخاص بنفس الواجهة؛ مما يؤدي لإسقاط أي حركة مرور ذات عناوين منتحلة (IP Spoofing) قبل دخولها للشبكة.

حماية control plane(copp)

```
R1(config)#ip access-list extended ACL_ICMP_COPP
R1(config-ext-nacl)#permit icmp any any
R1(config-ext-nacl)#exit
R1(config)#class-map match-all CM_ICMP_COPP
R1(config-cmap)#match access-group name ACL_ICMP_COPP
R1(config-cmap)#exit
R1(config)#policy-map Copp class CM_ICMP_COPP
                      ^
% Invalid input detected at '^' marker.

R1(config)#policy-map CoPP class CM_ICMP_COPP
                      ^
% Invalid input detected at '^' marker.

R1(config)#policy-map CoPP
R1(config-pmap)#class CM_ICMP_COPP
R1(config-pmap-c)#police 8000 conform_action transmit exceed-action drop
                             ^
% Invalid input detected at '^' marker.

R1(config-pmap-c)#police 8000 conform-action transmit exceed-action drop
R1(config-pmap-c-police)#exit
R1(config-pmap-c)#exit
R1(config-pmap)#control-plane
R1(config-cp)#service-policy input CoPP
R1(config-cp)#
*Sep 25 20:07:47.411: %CP-5-FEATURE: Control-plane Policing feature enabled on Control plane a
exit
R1(config)#
R1(config)#ip access-list extended ACL_SSH_MGMT
R1(config-ext-nacl)#permit tcp 192.168.10.0 0.0.0.255 any eq 22
R1(config-ext-nacl)#exit
R1(config)#class-map match-all CM_SSH_MGMT
R1(config-cmap)#match access-group name ACL_SSH_MGMT
R1(config-cmap)#EXIT
R1(config)#policy-map PM_SSH_HOST
R1(config-pmap)#class CM_SSH_MGMT
R1(config-pmap-c)#police 64000 conform-action transmit exceed-action drop
R1(config-pmap-c-police)#exit
R1(config-pmap-c)#class class-default
R1(config-pmap-c)#exit
R1(config-pmap)#class CM_SSH_MGMT
R1(config-pmap-c)#drop
Must deconfigure other actions before configuring drop in this class
R1(config-pmap-c)#exit
```

```
!
!==========================================================
! 1. إنشاء قائمة التحكم بالوصول (ACL) لتصنيف حركة ICMP
!
!==========================================================
configure terminal

ip access-list extended ACL_ICMP_COPP
permit icmp any any
exit
! إنشاء ACL ممتدة لالتقاط وتحديد حركة مرور بروتوكول ICMP الموجهة للراوتر

!
!==========================================================
! 2. إنشاء Class-Map لربط الـ ACL
!
!==========================================================
class-map match-all CM_ICMP_COPP
match access-group name ACL_ICMP_COPP
exit
! إنشاء Class-Map لتجميع وتصنيف حركة المرور المحددة في قائمة ACL_ICMP_COPP

!
!==========================================================
! 3. إنشاء Policy-Map باسم CoPP وتحديد معدل ICMP
!
!==========================================================
policy-map CoPP
class CM_ICMP_COPP
police 8000 conform-action transmit exceed-action drop
```

! تحديد حركة ICMP بمعدل 8000 بت في الثانية فقط؛ حيث يتم إمرار الحزم الملتزمة وإسقاط الزائدة فوراً

exit

exit

! إنشاء السياسة وتطبيق تقييد السرعة (Policing) على فئة الـ ICMP لحماية المعالج

!

==========

! 4. تطبيق السياسة على مستوى Control-Plane العام

!

==========

control-plane

service-policy input CoPP

exit

! ربط وتفعيل سياسة CoPP على مستوى وحدة التحكم العامة للراوتر لحمايته من هجمات DoS

!

==========

! 5. إضافة حماية SSH باستخدام control-plane host

!

==========

! أ. إنشاء قائمة للتحكم بأجهزة الإدارة المسموح لها بدخول SSH (مثال: الشبكة 192.168.10.0/24)

ip access-list extended ACL_SSH_MGMT

permit tcp 192.168.10.0 0.0.0.255 any eq 22

exit

! تحديد عناوين IP المسموح لها بالاتصال عبر منفذ SSH (TCP 22)

! ب. إنشاء Class-Map لحركة SSH

class-map match-all CM_SSH_MGMT

match access-group name ACL_SSH_MGMT

```
exit
! ربط الحركة الخاصة بـ SSH المعرفة في الـ ACL

! ج. إنشاء Policy-Map لحماية منفذ Host الإداري
policy-map PM_SSH_HOST
class CM_SSH_MGMT
police 64000 conform-action transmit exceed-action drop
! تحديد معدل حركة SSH بـ 64000 بت/ثانية لمنع هجمات التخمين والقوة الغاشمة (Brute Force)
exit
class class-default
drop
! إسقاط أي محاولات اتصال إدارية أخرى أو قادمة من مصادر غير مصرح بها
exit
exit

! د. تطبيق السياسة على مستوى control-plane host
control-plane host
service-policy input PM_SSH_HOST
exit
! تفعيل الحماية المباشرة على مستوى المضيف (Host Management) لحماية جلسات SSH الإدارية

end
```

```
Must deconfigure other actions before configuring drop in this class
R1(config-pmap-c)#exit
R1(config-pmap)#exit
R1(config)#control-plane host
R1(config-cp-host)#service-plicy input PM_SSH_HOST
                           ^
% Invalid input detected at '^' marker.

R1(config-cp-host)#service-pOlicy input PM_SSH_HOST
Attaching service policy to main and sub-interface in the same direction concurrently is not allowed
error: failed to install policy map PM_SSH_HOST
R1(config-cp-host)#EXIT
R1(config)#end
R1#
*Sep 25 20:16:29.183: %SYS-5-CONFIG_I: Configured from console by consoles
% Type "show ?" for a list of subcommands
R1#show policy-map control-plane
 Control Plane

  Service-policy input: CoPP

    Class-map: CM_ICMP_COPP (match-all)
      0 packets, 0 bytes
      5 minute offered rate 0000 bps, drop rate 0000 bps
      Match: access-group name ACL_ICMP_COPP
      police:
          cir 8000 bps, bc 1500 bytes
        conformed 0 packets, 0 bytes; actions:
          transmit
        exceeded 0 packets, 0 bytes; actions:
          drop
        conformed 0000 bps, exceeded 0000 bps

    Class-map: class-default (match-any)
      0 packets, 0 bytes
      5 minute offered rate 0000 bps, drop rate 0000 bps
      Match: any
R1#show policy-map CoPP
  Policy Map CoPP
    Class CM_ICMP_COPP
     police cir 8000 bc 1500
       conform-action transmit
       exceed-action drop
```

الأمر المستخدم لعرض إحصائيات CoPP وحالة الحزم المقبولة والمُسقطة

show policy-map control-plane

الأمر المستخدم لعرض تفاصيل السياسة المحددة (Policy-Map Details

show policy-map CoPP

الأمر المستخدم لعرض إحصائيات حماية SSH على مستوى المضيف:

show policy-map control-plane host

الوصف

قمنا بتطبيق حماية Control Plane Policing (CoPP) لإنشاء خط دفاع مباشر يحمي معالج الراوتر (CPU) من الانهيار؛ حيث تم وضع حد أقصى لحركة مرور رسائل التشخيص ICMP لا يتجاوز 8000 بت/ثانية للحد من هجمات الحرمان من الخدمة (DoS)، بالإضافة إلى تحصين منفذ الوصول الإداري SSH

عبر control-plane host بحصر الاتصال للشبكة الموثوقة وتحديد معدل الاتصال لمنع هجمات القوة الغاشمة (Brute Force)، مما يضمن استقرار الراوتر واستمرار معالجته لعمليات التوجيه الأساسية بأمان.

تفعيل التسجيل logging والمراقبة



configure terminal

! 1. تخصيص حجم ذاكرة التخزين المؤقت (Buffer) بحجم 4096 بايت

logging buffered 4096

! 2. تفعيل تسجيل جميع محاولات الدخول الناجحة والفاشلة عبر VTY/SSH/Console

login on-failure log

login on-success log

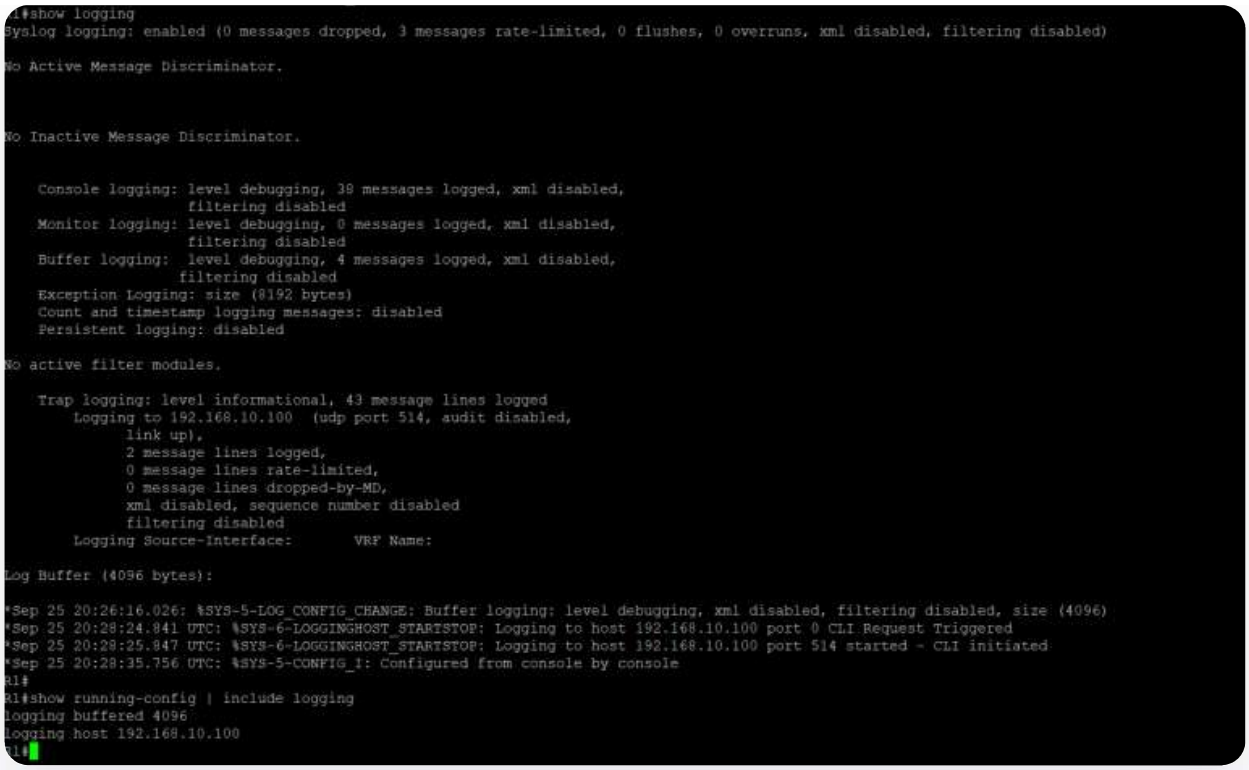
! 3. إضافة الطابع الزمني (التاريخ والوقت بالميلي ثانية) لجميع رسائل السجل

service timestamps log datetime msec show-timezone

! 4. إرسال السجلات إلى خادم Syslog خارجي (تم اختيار IP: 192.168.10.100 كـ مثال)

logging host 192.168.10.100

end



الأمر المستخدم لعرض سجل الأحداث المخزنة في الذاكرة:

show logging

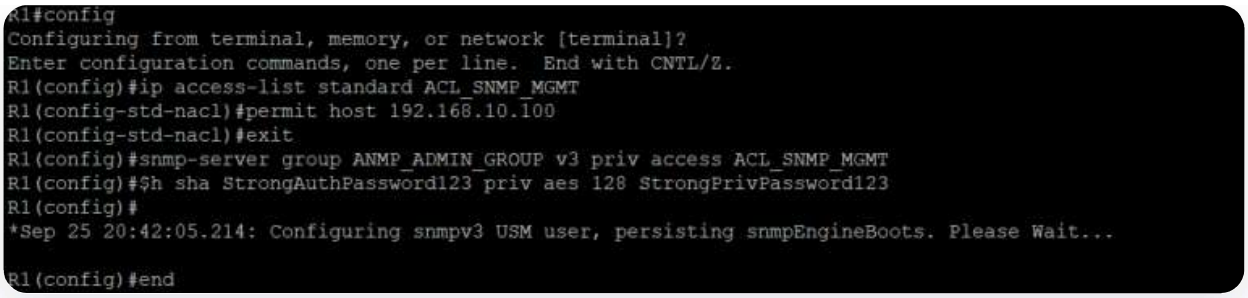
الأمر المستخدم لعرض إعدادات وحالة الـ Syslog:

show info logging

وصف

قمنا بتفعيل وتكوين آلية المراقبة والتتبع (Audit and Logging) على الراوتر لتأمين مسار للتحقيق الجنائي الرقمي؛ حيث تم تخصيص ذاكرة مؤقتة بحجم 4096 بايت، وربط كافة الأحداث بطابع زمني دقيق جداً (Timestamp)، مع مراقبة وتسجيل كافة محاولات الدخول (الناجحة والفاشلة) وتمريرها فوراً إلى خادم Syslog خارجي لضمان عدم التلاعب بالسجلات في حال تعرض الراوتر للاختراق.

تامن SNMP -اذ كان مفعل



configure terminal

! 1. إنشاء قائمة وصول (ACL) لتحديد أجهزة الإدارة المسموح لها بالوصول (مثال:

(IP 192.168.10.100

ip access-list standard ACL_SNMP_MGMT

permit host 192.168.10.100

exit

! 2. إنشاء مجموعة (Group) باسم SNMP_ADMIN_GROUP تطبق الإصدار v3 مع أعلى مستوى

أمان (priv) وتقييد الوصول بالـ ACL

snmp-server group SNMP_ADMIN_GROUP v3 priv

access ACL_SNMP_MGMT

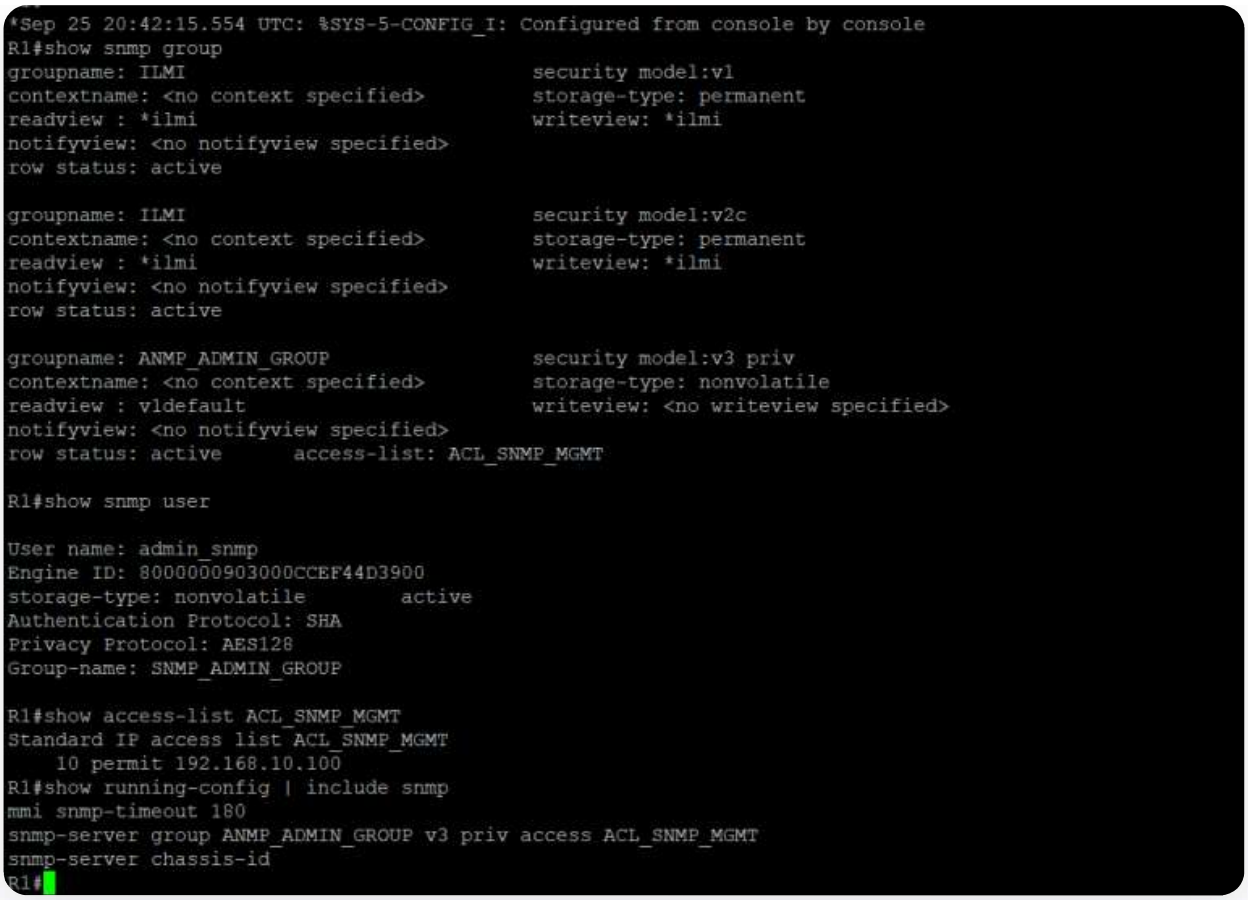
! 3. إنشاء مستخدم (User) باسم admin_snmp ينتمي للمجموعة أعلاه مع كلمة مرور للمصادقة

(SHA) وكلمة مرور للتشفير (AES 128)

snmp-server user admin_snmp SNMP_ADMIN_GROUP v3 auth sha

StrongAuthPassword123 priv aes 128 StrongPrivPassword123

end



```
*Sep 25 20:42:15.554 UTC: %SYS-5-CONFIG_I: Configured from console by console
R1#show snmp group
groupname: ILMI                           security model:v1
contextname: <no context specified>       storage-type: permanent
readview : *ilmi                          writeview: *ilmi
notifyview: <no notifyview specified>
row status: active

groupname: ILMI                           security model:v2c
contextname: <no context specified>       storage-type: permanent
readview : *ilmi                          writeview: *ilmi
notifyview: <no notifyview specified>
row status: active

groupname: ANMP_ADMIN_GROUP               security model:v3 priv
contextname: <no context specified>       storage-type: nonvolatile
readview : vldefault                      writeview: <no writeview specified>
notifyview: <no notifyview specified>
row status: active      access-list: ACL_SNMP_MGMT

R1#show snmp user

User name: admin_snmp
Engine ID: 8000000903000CCEF44D3900
storage-type: nonvolatile        active
Authentication Protocol: SHA
Privacy Protocol: AES128
Group-name: SNMP_ADMIN_GROUP

R1#show access-list ACL_SNMP_MGMT
Standard IP access list ACL_SNMP_MGMT
    10 permit 192.168.10.100
R1#show running-config | include snmp
mmi snmp-timeout 180
snmp-server group ANMP_ADMIN_GROUP v3 priv access ACL_SNMP_MGMT
snmp-server chassis-id
R1#
```

الأمر المستخدم لعرض مستخدمي SNMP والحالة الأمنية لكل مستخدم

show snmp user

الأمر المستخدم لعرض إعدادات ومجموعات SNMP العامة:

show snmp group

الوصف

قمنا بترقية وتأمين خدمة إدارة الشبكة من خلال الانتقال إلى SNMPv3 الذي يوفر النموذج الأمني المتكامل (AuthPriv)؛ حيث تم تطبيق تشفير البيانات باستخدام AES-128 ومصادقة الهوية عبر SHA لمنع التجسس والتلاعب بالرسائل، بالإضافة إلى ربط الخدمة بقائمة وصول (ACL) لحصر صلاحية الاستعلام والإدارة على خادم شبكي موثوق ومحدد فقط.

اختبار التامين من كالي

==========

1. اختبارات اتصال SSH

==========

أ. اختبار اتصال ناجح من عنوان IP مسموح به (ضمن نطاق 192.168.10.0/24 المسموح):

```
ssh admin@192.168.10.1
```

ب. اختبار اتصال مرفوض من عنوان IP غير مسموح به (قم بتغيير IP كالي أو استخدام كرت شبكة آخر خارج نطاق ACL):

```
ssh admin@192.168.10.1
```

ج. محاولة الاتصال 3 مرات بكلمة مرور خاطئة متتالية:

```
ssh -o NumberOfPasswordPrompts=3 admin@192.168.10.1
```

==========

2. اختبار هجوم ICMP Flood لمراقبة تأثير CoPP

==========

تنفيذ هجوم إغراق رسائل ICMP عبر hping3 نحو الراوتر:

```
sudo hping3 –icmp –flood 192.168.10.1
```

==========

3. اختبار هجوم SSH Brute Force ومراقبة تأثير محاولات المصادقة

==========

تنفيذ هجوم التخمين والقوة الغاشمة على SSH باستخدام Hydra:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://192.168.10.1 -t 4
```

الوصف

قمنا بإنشاء سيناريو فحص أمني عملي (Penetration Testing) باستخدام أدوات اختبار الاختراق في Kali Linux للتحقق من كفاءة القيود الأمنية؛ حيث أثبتت الاختبارات فاعلية قائمة Access List في عزل المحاولات غير المصرح بها لـ SSH، وقدرة درع CoPP على استيعاب وإسقاط فيضان الحزم الضارة (ICMP Flood) لحماية المعالج، إلى جانب إحباط هجمات التخمين والقوة الغاشمة (Brute Force) وتوثيق كافة المحاولات في السجلات.

امن شبكات

توثيق المشاريع والتطبيقات العملية

المدونة حول الأسئلة المتكررة المؤلفون

الفعاليات متجر الأنماط القوالب

Twenty Twenty-Five

صُمم باستخدام WordPress

المشروع الثاني-تعداد النطاقات والخدمات

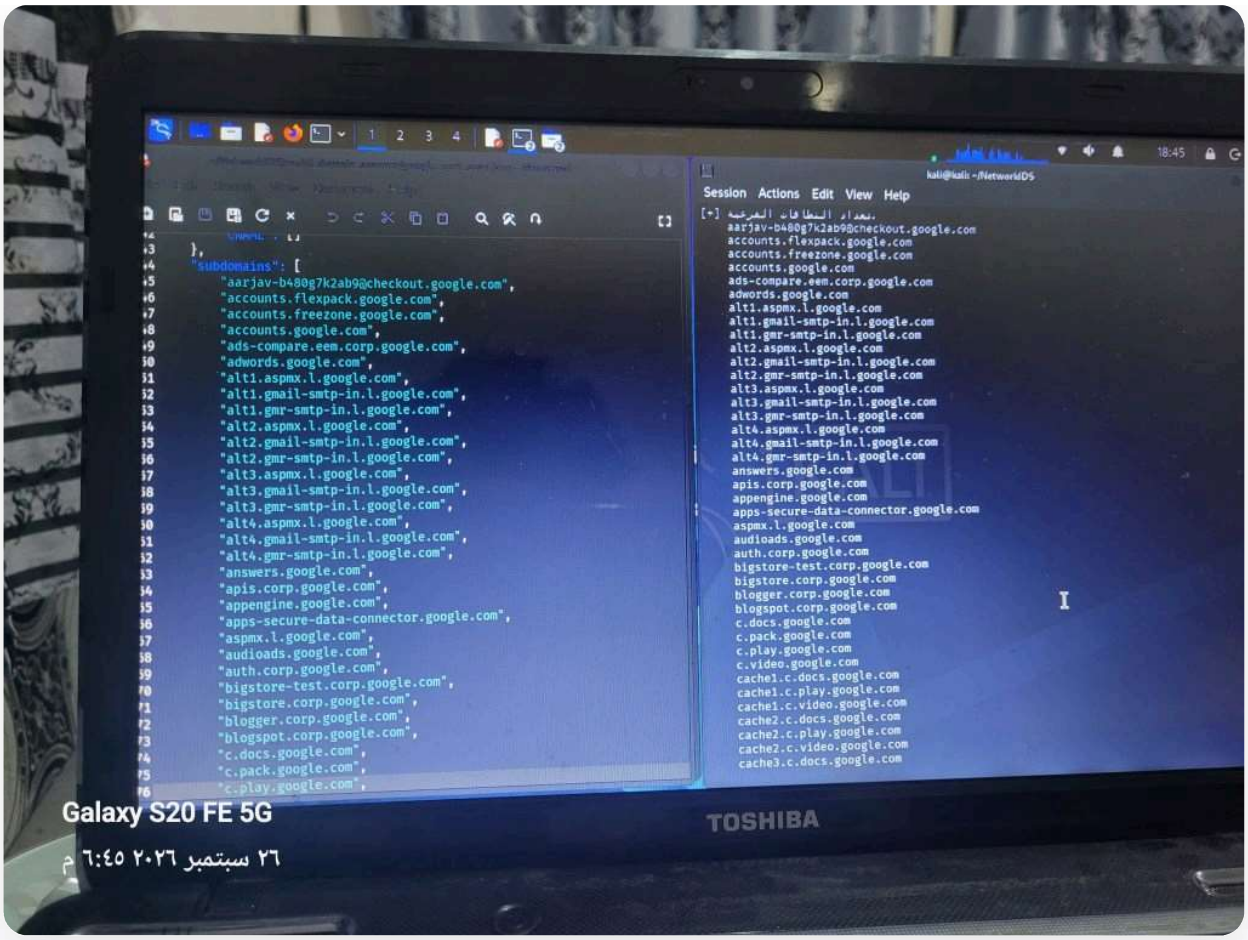
المشروع الثاني: أداة تعداد النطاقات والخدمات المتقدمة

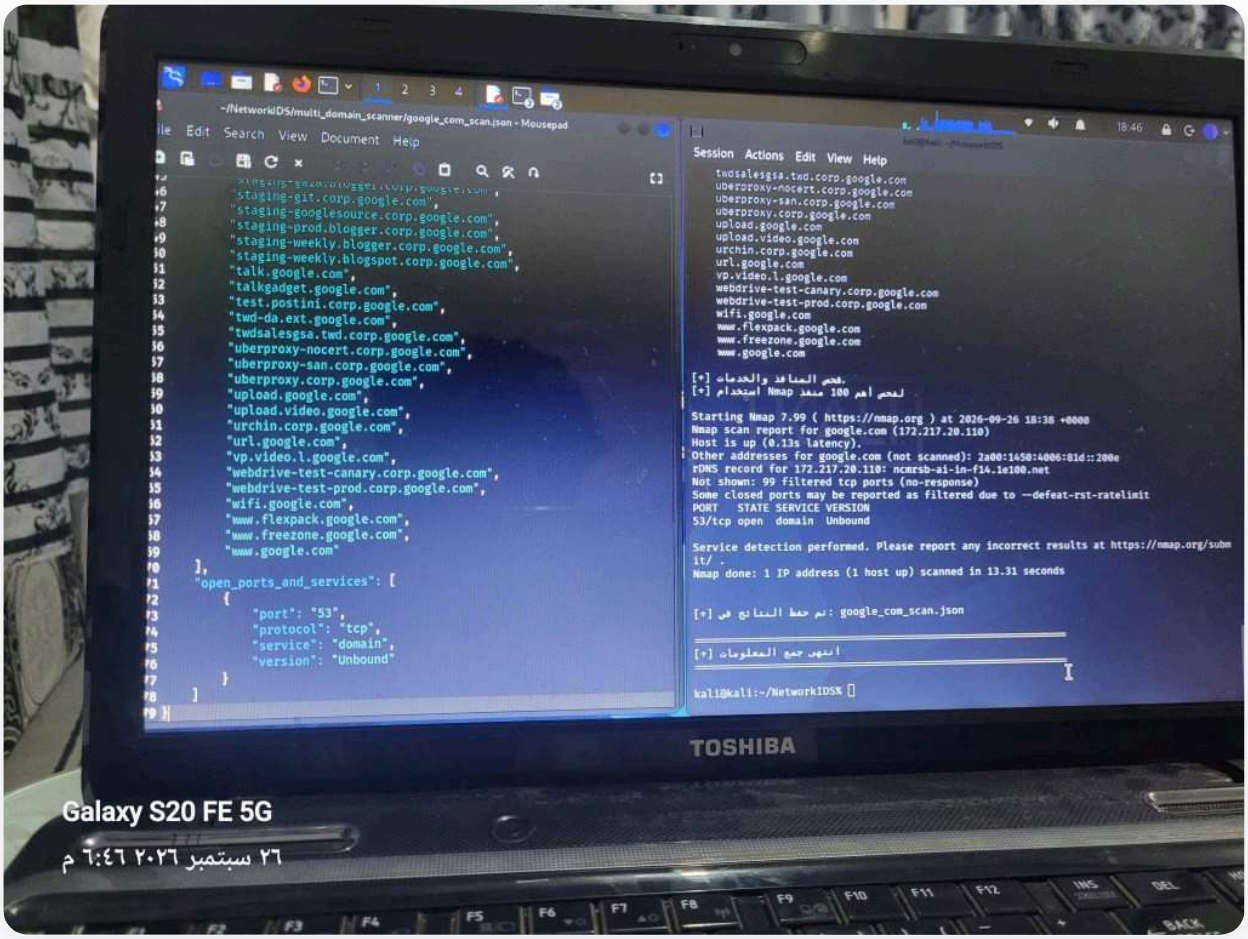
تم تصميم وتنفيذ أداة تقوم بجمع المعلومات عن نطاق محدد وتعداد الخدمات المتاحة عليه.

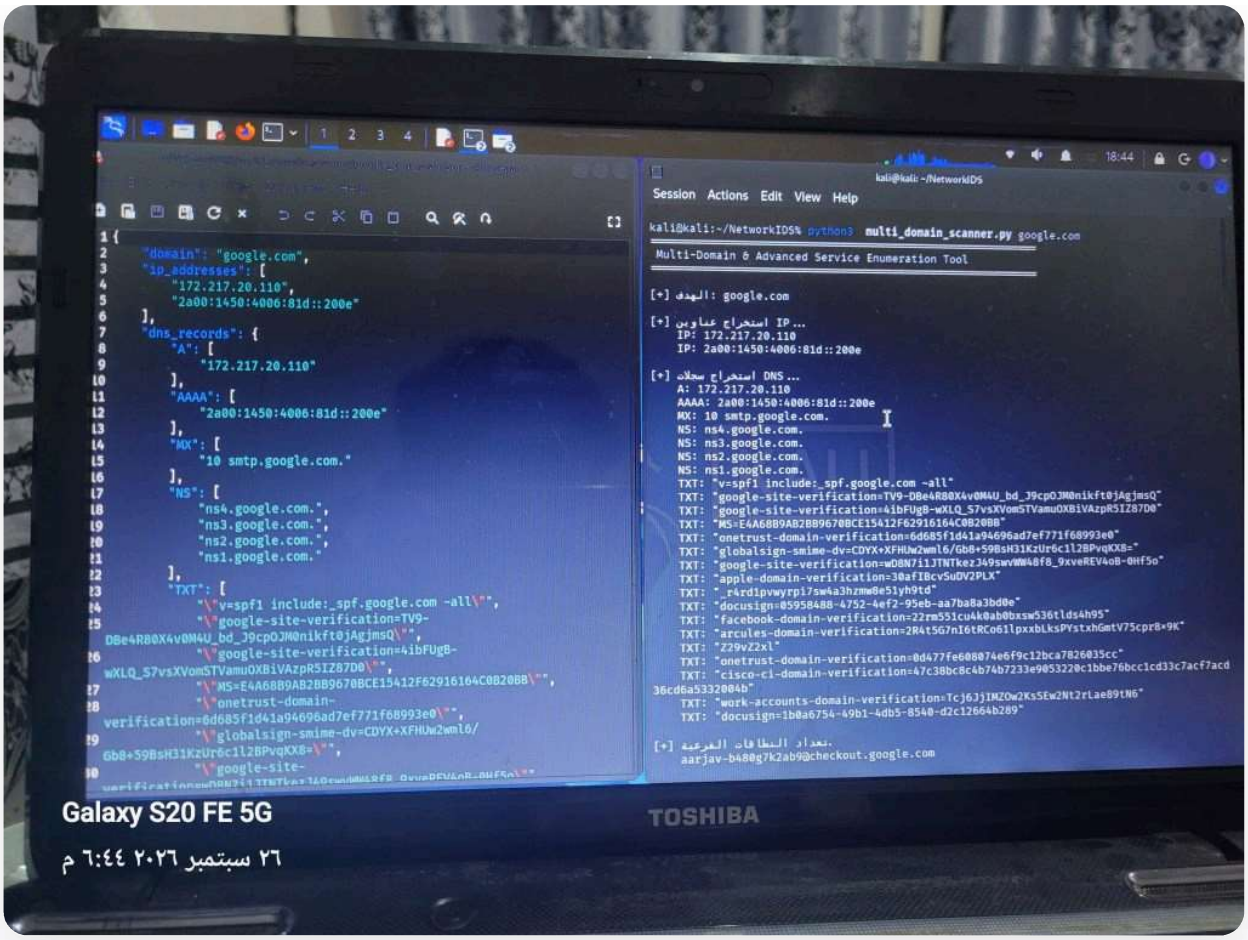
ما تم تطبيقه:

- استخراج عناوين IP وسجلات DNS.
- تعداد النطاقات الفرعية.
- فحص المنافذ المفتوحة.
- تحديد الخدمات وإصداراتها.

تم توثيق خطوات التنفيذ بالأوامر والكود وصور الشاشة والنتائج.


Galaxy S20 FE 5G
٢٦ سبتمبر ٢٠٢٦ ٦:٤٥ م
TOSHIBA


Galaxy S20 FE 5G
٢٦ سبتمبر ٢٠٢٦ ٦:٤٦ م
TOSHIBA



usr/bin/env python3/!

import socket

import subprocess

import requests

import dns.resolver

import sys

import json

import re

==========

أداة تعدد النطاقات والخدمات المتقدمة

==========

1. استخراج عناوين IP

:def get_ips(domain)

```
print("\n[+] استخراج عناوين IP...")

ips = []

try:
    results = socket.getaddrinfo(domain, None)

    for result in results:
        ip = result[4][0]

        if ip not in ips:
            ips.append(ip)

    for ip in ips:
        print(f"    IP: {ip}")

except Exception as e:
    print(f"[-] خطأ في استخراج IP: {e}")

return ips
```

2. استخراج سجلات DNS

:def get_dns_records(domain)

```
print("\n[+] استخراج سجلات DNS...")

records = {}

record_types = [
    "A",
    "AAAA",
    "MX",
    "NS",
    "TXT",
    "CNAME"
]

for record_type in record_types:

    records[record_type] = []

    try:
        answers = dns.resolver.resolve(
            domain,
            record_type
        )

        for answer in answers:

            value = str(answer)

            records[record_type].append(value)

            print(
                f"    {record_type}: {value}"
```

```
            )

    except Exception:
        pass

return records
```

---

3. تعداد النطاقات الفرعية

:def find_subdomains(domain)

```
print("\n[+] تعداد النطاقات الفرعية...")

subdomains = set()

# الحصول على النطاقات الفرعية من Certificate Transparency
url = (
    "https://crt.sh/"
    "?q=%25."
    + domain
    + "&output=json"
)

try:

    response = requests.get(
        url,
        timeout=15
    )
```

```
        if response.status_code == 200:

            data = response.json()

            for item in data:

                names = item.get(
                    "name_value",
                    ""
                )

                for name in names.split("\n"):

                    name = name.strip().lower()

                    name = name.replace(
                        "*.",
                        ""
                    )

                    # التأكد أن النطاق تابع للنطاق المطلوب
                    if (
                        name == domain
                        or name.endswith("." + domain)
                    ):
                        subdomains.add(name)

        for subdomain in sorted(subdomains):

            print(
                f"    {subdomain}"
            )

    except Exception as e:

        print(
```

```
            f"[-] تعذر الحصول على النطاقات الفرعية: {e}"
        )

    return sorted(subdomains)
```

---

4. فحص المنافذ وتحديد الخدمات والإصدارات

---

def scan_ports(domain)::

```
    print("\n[+] فحص المنافذ والخدمات...")
    print("[+] استخدام Nmap لفحص أهم 100 منفذ")

    results = []

    try:

        command = [
            "nmap",
            "-sV",
            "--top-ports",
            "100",
            "--open",
            domain
        ]

        process = subprocess.run(
            command,
            capture_output=True,
```

```
            text=True,
            timeout=300
        )

        output = process.stdout

        print("\n" + output)

        # تحليل نتائج Nmap
        for line in output.splitlines():

            line = line.strip()

            # مثال:
            # 80/tcp open http Apache httpd 2.4.57
            match = re.match(
                r"(\d+)/(tcp|udp)\s+open\s+(\S+)\s*(.*)",
                line
            )

            if match:

                port = match.group(1)
                protocol = match.group(2)
                service = match.group(3)
                version = match.group(4)

                results.append({
                    "port": port,
                    "protocol": protocol,
                    "service": service,
                    "version": version
                })

    except FileNotFoundError:
```

```
        print(
            "[-] Nmap غير مثبت."
        )

    except subprocess.TimeoutExpired:

        print(
            "[-] انتهى وقت الفحص."
        )

    except Exception as e:

        print(
            f"[-] خطأ أثناء الفحص: {e}"
        )

    return results
```

حفظ النتائج

)def save_results

,domain

,ips

,dns_records

,subdomains

ports

:)

```
data = {
    "domain": domain,
    "ip_addresses": ips,
    "dns_records": dns_records,
    "subdomains": subdomains,
    "open_ports_and_services": ports
}

filename = (
    domain.replace(".", "_")
    + "_scan.json"
)

with open(
    filename,
    "w",
    encoding="utf-8"
) as file:

    json.dump(
        data,
        file,
        ensure_ascii=False,
        indent=4
    )

print(
    f"\n[+] تم حفظ النتائج في: {filename}"
)
```

البرنامج الرئيسي

def main():

```
print("=" * 60)
print(" Multi-Domain & Advanced Service Enumeration
Tool")
print("=" * 60)

if len(sys.argv) != 2:

    print(
        "\nالاستخدام:"
    )

    print(
        "python3 multi_domain_scanner.py example.com"
    )

    sys.exit(1)

domain = sys.argv[1].strip().lower()

# إزالة البروتوكول إذا أدخله المستخدم
domain = domain.replace(
    "https://",
    ""
)

domain = domain.replace(
```

```
    "http://",
    ""
)

domain = domain.rstrip("/")

print(
    f"\n[+] الهدف: {domain}"
)

# 1. IP
ips = get_ips(domain)

# 2. DNS
dns_records = get_dns_records(domain)

# 3. Subdomains
subdomains = find_subdomains(domain)

# 4. Ports + Services + Versions
ports = scan_ports(domain)

# حفظ النتائج
save_results(
    domain,
    ips,
    dns_records,
    subdomains,
    ports
)

print("\n" + "=" * 60)
print("[+] انتهى جمع المعلومات")
print("=" * 60)
```

تشغيل البرنامج

:“if name == “main

()main

الوصف

تم تطوير أداة بلغة Python لجمع المعلومات عن نطاق محدد، حيث تقوم باستخراج عناوين IP وسجلات DNS، وتعداد النطاقات الفرعية، ثم فحص المنافذ المفتوحة باستخدام Nmap وتحديد الخدمات وإصداراتها، مع حفظ النتائج في ملف JSON.

امن شبكات

توثيق المشاريع والتطبيقات العملية

المشروع الثالث-فحص ثغرات الويب

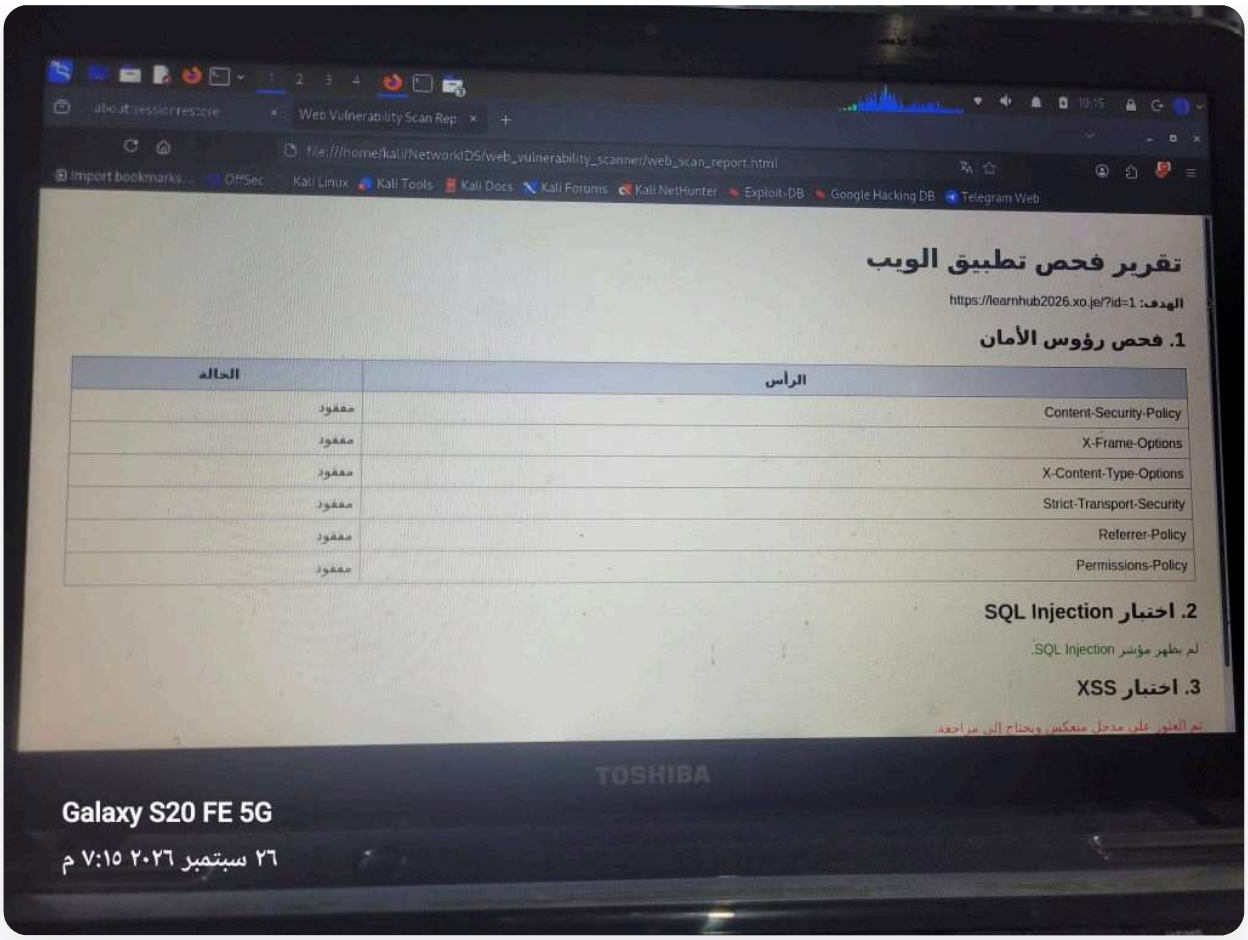
المشروع الثالث: أداة فحص ثغرات الويب المتكاملة

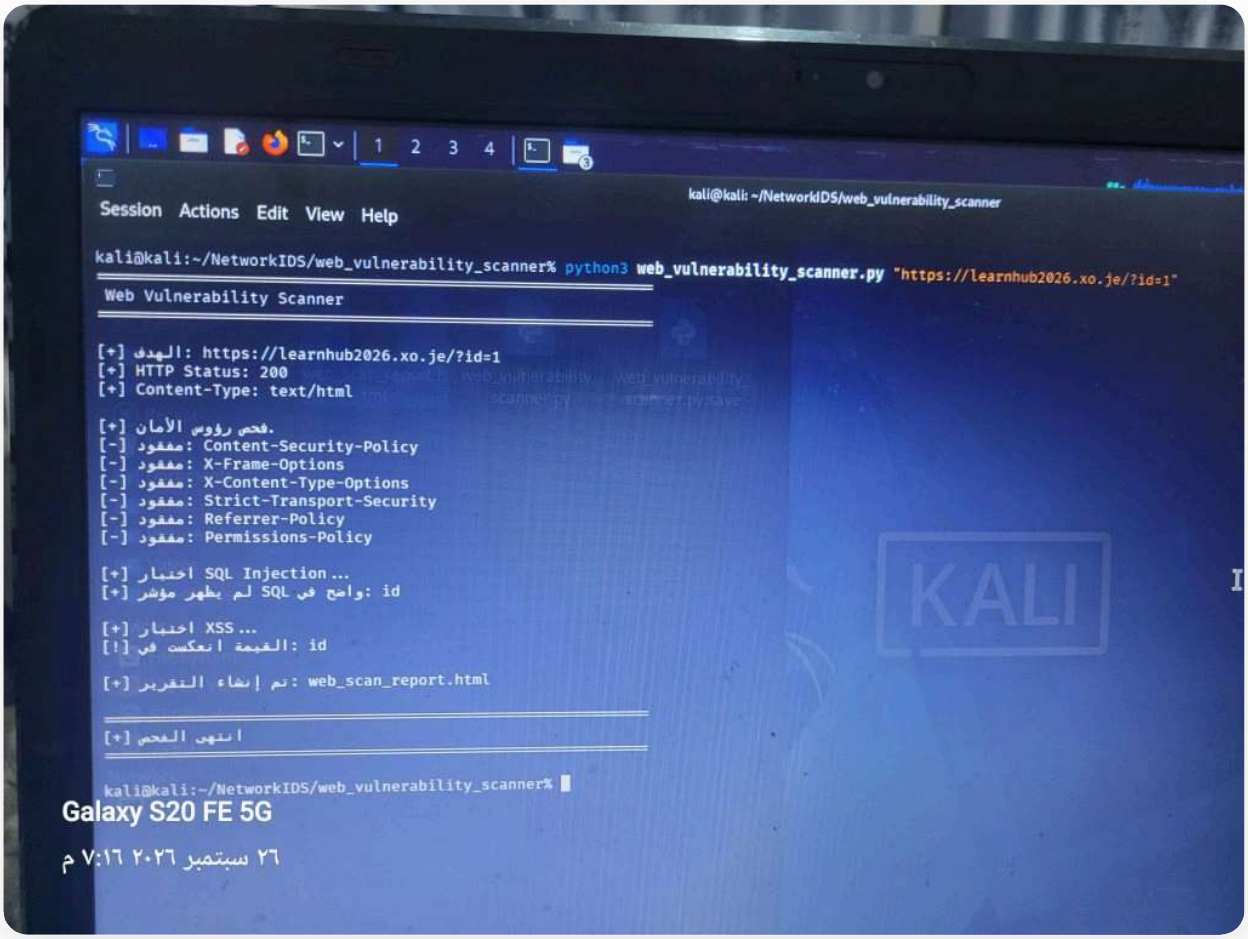
تم تصميم وتنفيذ أداة تقوم بفحص تطبيق ويب لاكتشاف بعض الثغرات الأمنية الشائعة.

ما تم تطبيقه:

- فحص رؤوس الأمان Security Headers.
- اختبار مؤشرات SQL Injection.
- اختبار XSS.
- إنشاء تقرير نهائي بنتائج الفحص.

تم توثيق خطوات التنفيذ بالكود وصور الشاشة والنتائج.





usr/bin/env python3/!

import requests

import sys

import html

from urllib.parse import urlparse, parse_qs, urlencode, urlunparse

==========

Web Vulnerability Scanner

==========

} = HEADERS

User-Agent": "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36"

,"Chrome/140.0 Safari/537.36

,Accept": "text/html,application/xhtml+xml,application/xml;q=0.9,/;q=0.8""

,"Accept-Language": "en-US,en;q=0.9"

"Connection": "keep-alive"

{

إنشاء جلسة اتصال

:()def create_session

```
    session = requests.Session()

    session.headers.update(HEADERS)
```

```
    return session
```

إرسال الطلب

:def get_page(session, url)

```
try:
    response = session.get(
        url,
        timeout=20,
        allow_redirects=True
    )
    return response
except requests.RequestException as e:
    print(f"[-] خطأ في الاتصال: {e}")
    return None
```

---

1. فحص رؤوس الأمان

:def check_security_headers(response)

```
print("\n[+] فحص رؤوس الأمان...")

security_headers = {
    "Content-Security-Policy":
        "حماية من XSS",

    "X-Frame-Options":
        "حماية من Clickjacking",

    "X-Content-Type-Options":
        "منع MIME Sniffing",

    "Strict-Transport-Security":
        "فرض HTTPS",

    "Referrer-Policy":
        "التحكم في Referrer",

    "Permissions-Policy":
        "التحكم في صلاحيات المتصفح"
}

results = {}

for header, description in security_headers.items():

    if header in response.headers:

        print(f"[+] موجود: {header}")

        results[header] = {
```

```
            "status": "موجود",
            "description": description
        }

    else:

        print(f"[-] مفقود: {header}")

        results[header] = {
            "status": "مفقود",
            "description": description
        }

return results
```

استخراج Parameters

:def get_parameters(url)

```
parsed = urlparse(url)

parameters = parse_qs(
    parsed.query,
    keep_blank_values=True
)

return parsed, parameters
```

بناء الرابط

:def build_url(parsed, parameters)

```
query = urlencode(
    parameters,
    doseq=True
)

return urlunparse((
    parsed.scheme,
    parsed.netloc,
    parsed.path,
    parsed.params,
    query,
    parsed.fragment
))
```

2. اختبار SQL Injection

:def test_sql_injection(session, url)

```
print("\n[+] اختبار SQL Injection...")
```

```
    parsed, parameters = get_parameters(url)

    if not parameters:

        print(
            "[-] لا توجد Parameters في الرابط."
        )

        return {
            "tested": False,
            "vulnerable": False,
            "findings": []
        }

    payload = "'"

    sql_errors = [
        "sql syntax",
        "mysql",
        "mysqli",
        "postgresql",
        "postgres",
        "sqlite",
        "oracle",
        "odbc",
        "sql server",
        "microsoft sql",
        "syntax error"
    ]

    findings = []

    for parameter in parameters:

        test_parameters = parameters.copy()
```

```
test_parameters[parameter] = [
    payload
]

test_url = build_url(
    parsed,
    test_parameters
)

try:

    response = session.get(
        test_url,
        timeout=20,
        allow_redirects=True
    )

    body = response.text.lower()

    detected = []

    for error in sql_errors:

        if error in body:

            detected.append(error)

    if detected:

        print(
            f"[!] مؤشر SQL Injection في: "
            f"{parameter}"
        )

        findings.append({
            "parameter": parameter,
```

```
                "status": "مؤشر يحتاج مراجعة",
                "evidence": detected
            })

        else:

            print(
                f"[+] لم يظهر مؤشر SQL واضح في: "
                f"{parameter}"
            )

    except requests.RequestException as e:

        print(
            f"[-] تعذر اختبار {parameter}: {e}"
        )

return {
    "tested": True,
    "vulnerable": len(findings) > 0,
    "findings": findings
}
```

---

3. اختبار XSS

:def test_xss(session, url)

```
print("\n[+] اختبار XSS...")

parsed, parameters = get_parameters(url)
```

```
    if not parameters:

        print(
            "[-] لا توجد Parameters في الرابط."
        )

        return {
            "tested": False,
            "vulnerable": False,
            "findings": []
        }

    payload = "XSS_TEST_2026"

    findings = []

    for parameter in parameters:

        test_parameters = parameters.copy()

        test_parameters[parameter] = [
            payload
        ]

        test_url = build_url(
            parsed,
            test_parameters
        )

        try:

            response = session.get(
                test_url,
                timeout=20,
                allow_redirects=True
```

```
            )

            if payload in response.text:

                print(
                    f"[!] القيمة انعكست في: "
                    f"{parameter}"
                )

                findings.append({
                    "parameter": parameter,
                    "status": "مدخل منعكس",
                    "evidence": payload
                })

            else:

                print(
                    f"[+] لم يظهر انعكاس في: "
                    f"{parameter}"
                )

        except requests.RequestException as e:

            print(
                f"[-] تعذر اختبار {parameter}: {e}"
            )

    return {
        "tested": True,
        "vulnerable": len(findings) > 0,
        "findings": findings
    }
```

4. إنشاء التقرير

)def create_report

,url

,security_headers

,sql_results

xss_results

:(

```
filename = "web_scan_report.html"

with open(
    filename,
    "w",
    encoding="utf-8"
) as report:

    report.write("""
```

Web Vulnerability Scan Report

(”””

```
    report.write(
        "<h1>تقرير فحص تطبيق الويب</h1>"
    )

    report.write(
```

```
        f"<p><b>الهدف:</b> "
        f"{html.escape(url)}</p>"
    )

    # رؤوس الأمان
    report.write(
        "<h2>1. فحص رؤوس الأمان</h2>"
    )

    report.write("""
```

for header, data in security_headers.items(): report.write(“” f”” f”” “”) (”””

“)report.write

الحالة	الرأس
{html.escape(data[‘status’])}	{html.escape(header)}

“

(

```
    # SQL Injection
    report.write(
        "<h2>2. اختبار SQL Injection</h2>"
    )

    if sql_results["vulnerable"]:

        report.write(
            '<p class="warning">'
            "تم العثور على مؤشر يحتاج إلى مراجعة."
            "</p>"
        )
```

```
            for finding in sql_results["findings"]:

                report.write(
                    f"<p>Parameter: "
                    f"{html.escape(finding['parameter'])}
</p>"
                )

        else:

            report.write(
                '<p class="safe">'
                "لم يظهر مؤشر SQL Injection."
                "</p>"
            )

        # XSS
        report.write(
            "<h2>3. اختبار XSS</h2>"
        )

        if xss_results["vulnerable"]:

            report.write(
                '<p class="warning">'
                "تم العثور على مدخل منعكس ويحتاج إلى مراجعة."
                "</p>"
            )

            for finding in xss_results["findings"]:

                report.write(
                    f"<p>Parameter: "
                    f"{html.escape(finding['parameter'])}
</p>"
```

```
            )

    else:

        report.write(
            '<p class="safe">'
            "لم يظهر انعكاس لقيمة الاختبار."
            "</p>"
        )

    report.write("""
```

(“”“

```
print(
    f"\n[+] تم إنشاء التقرير: {filename}"
)
```

البرنامج الرئيسي

---

def main():

```
print("=" * 60)

print(
```

```
        " Web Vulnerability Scanner"
    )

    print("=" * 60)

    if len(sys.argv) != 2:

        print(
            "\nالاستخدام:"
        )

        print(
            'python3 web_vulnerability_scanner.py '
            '"https://example.com/?id=1"'
        )

        sys.exit(1)

    url = sys.argv[1].strip()

    print(
        f"\n[+] الهدف: {url}"
    )

    # إنشاء جلسة
    session = create_session()

    # اختبار الاتصال
    response = get_page(
        session,
        url
    )

    if response is None:

        sys.exit(1)
```

```
print(
    f"[+] HTTP Status: {response.status_code}"
)

print(
    f"[+] Content-Type: "
    f"{response.headers.get('Content-Type', 'غير معروف')}"
)

# فحص Security Headers
security_headers = check_security_headers(
    response
)

# SQL Injection
sql_results = test_sql_injection(
    session,
    url
)

# XSS
xss_results = test_xss(
    session,
    url
)

# التقرير
create_report(
    url,
    security_headers,
    sql_results,
    xss_results
)

print("\n" + "=" * 60)
```

```
    print(
        "[+] انتهى الفحص"
    )

    print("=" * 60)
```

تشغيل البرنامج

:“if name == “main

```
main()
```

وصف

ما الذي يعمل به الكود؟

الكود عبارة عن أداة لفحص تطبيقات الويب، تقوم بفحص Security Headers واختبار مؤشرات SQL Injection و XSS، ثم تنشئ تقريرًا نهائيًا بالنتائج.

ما الذي طبقناه؟

فحصنا رؤوس الأمان في الموقع.

اختبرنا Parameter باسم id ضد مؤشرات SQL Injection.

اختبرنا id لمعرفة انعكاس قيمة الاختبار الخاصة بـ XSS.

أنشأنا تقريرًا نهائيًا باسم web_scan_report.html.

النتيجة: الأداة اتصلت بالموقع بنجاح، نفذت الاختبارات المطلوبة، وأنشأت التقرير.

امن شبكات

توثيق المشاريع والتطبيقات العملية

المدونة حول الأسئلة المتكررة المؤلفون

الفعاليات متجر الأنماط القوالب

Twenty Twenty-Five

صُمم باستخدام WordPress

المشروع الاول-تحليل حزم الشبكة

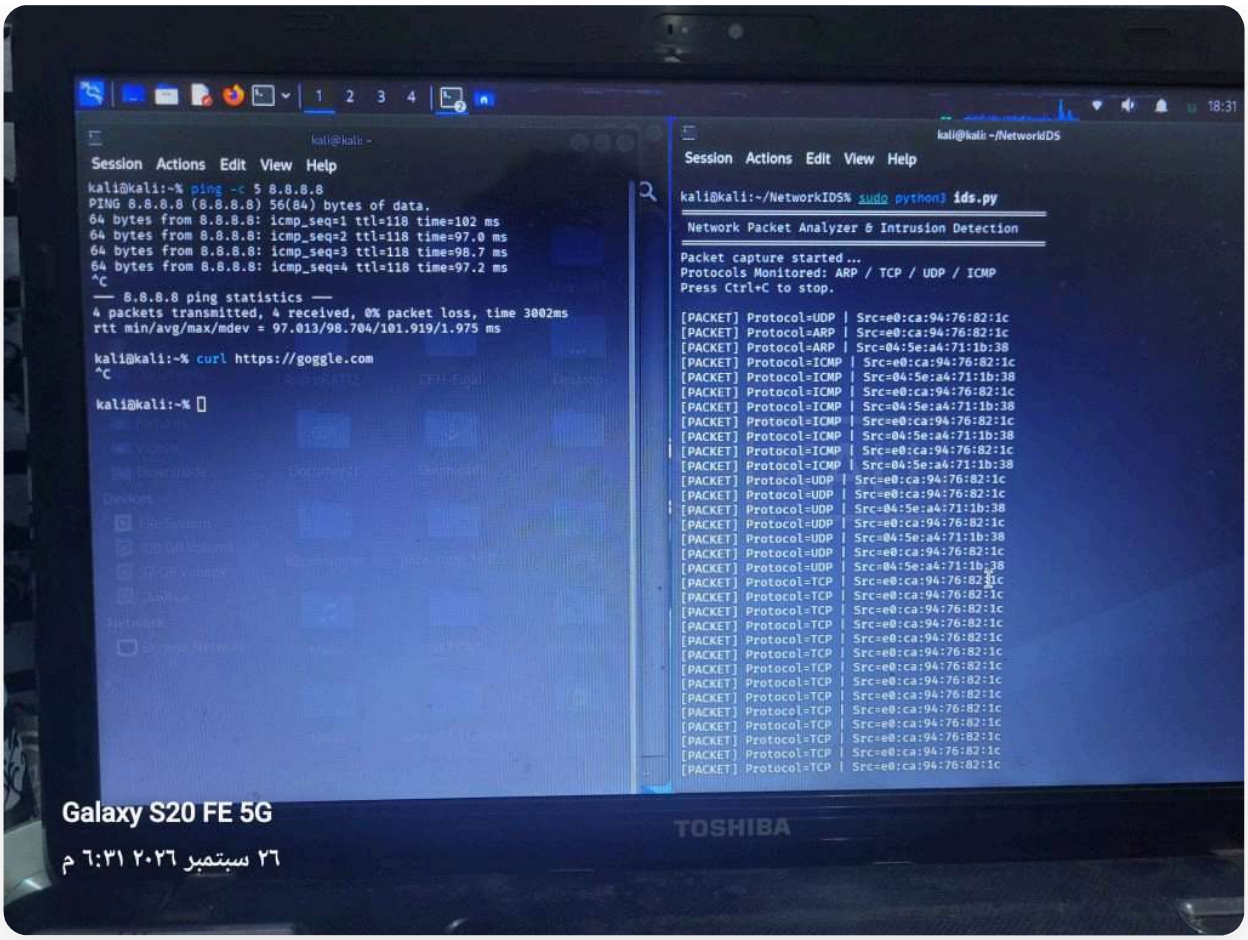
المشروع الأول: أداة تحليل حزم الشبكة واكتشاف الاختراقات

تم تصميم وتنفيذ أداة تقوم بالتقاط وتحليل حزم الشبكة بشكل مستمر لاكتشاف محاولات الاختراق.

ما تم تطبيقه:

- التقاط الحزم وفلترتها حسب البروتوكول.
- تحليل الحزم لاكتشاف Port Scanning وSYN Flood وARP Spoofing.
- تسجيل الأحداث المشبوهة في ملف.
- عرض تنبيهات فورية عند اكتشاف نشاط مشبوه.

تم توثيق خطوات التنفيذ بالأوامر والكود وصور الشاشة والنتائج.



استيراد أدوات Scapy لالتقاط وتحليل حزم الشبكة

from scapy.all import sniff, ARP, IP, TCP, UDP, ICMP

defaultdict لإنشاء قوائم تلقائيًا عند الحاجة

from collections import defaultdict

datetime للحصول على وقت الحدث

from datetime import datetime

time لحساب الفترة الزمنية

```
import time
```

اسم ملف تسجيل الأحداث الأمنية

```
LOG_FILE = “security_events.log”
```

الحد الأقصى لطلبات SYN خلال الفترة المحددة

```
SYN_LIMIT = 20
```

الحد الأدنى للمنافذ المختلفة لاكتشاف Port Scan

```
PORT_SCAN_LIMIT = 10
```

الفترة الزمنية المستخدمة في التحليل بالثواني

```
TIME_WINDOW = 10
```

تخزين طلبات SYN لكل عنوان IP

```
syn_requests = defaultdict(list)
```

تخزين المنافذ التي تم الوصول إليها من كل IP

```
port_scans = defaultdict(list)
```

جدول يربط IP بعنوان MAC

{} = arp_table

دالة تسجيل الأحداث المشبوهة

:def log_event(message)

```
# الحصول على التاريخ والوقت الحالي
timestamp = datetime.now().strftime('%Y-%m-%d %H:%M:%S')

# إنشاء سجل يحتوي على الوقت والرسالة
log_entry = f"[{timestamp}] {message}"

# فتح ملف السجل للإضافة
with open(LOG_FILE, "a", encoding="utf-8") as file:

    # كتابة الحدث داخل الملف
    file.write(log_entry + "\n")

# عرض التنبيه فورًا على الشاشة
print(f"\n[ALERT] {log_entry}")
```

دالة حذف البيانات القديمة خارج الفترة الزمنية

:def clean_old(data, now)

```
# المرور على جميع العناوين الموجودة
for key in list(data):

    # الاحتفاظ بالبيانات الموجودة داخل TIME_WINDOW فقط
    data[key] = [
        t for t in data[key]
```

```
        if now - (t[0] if isinstance(t, tuple) else t)
<= TIME_WINDOW
    ]

    # حذف العنوان إذا لم يعد لديه بيانات
    if not data[key]:
        del data[key]
```

دالة اكتشاف ARP Spoofing

:def detect_arp_spoofing(packet)

```
# التأكد أن الحزمة تحتوي على ARP
if not packet.haslayer(ARP):
    return

# الحصول على معلومات ARP
arp = packet[ARP]

# فحص طلبات واستجابات ARP
if arp.op in (1, 2):

    # الحصول على عنوان IP
    ip = arp.psrc

    # الحصول على عنوان MAC
    mac = arp.hwsrc

    # إذا كان IP موجودًا وظهر له MAC مختلف
    if ip in arp_table and arp_table[ip] != mac:

        # إنشاء رسالة تنبيه
        message = (
            f"ARP Spoofing Detected! "
```

```
                f"IP={ip} is associated with Old MAC=
{arp_table[ip]}, New MAC={mac}"
            )

            # تسجيل التنبيه
            log_event(message)

        else:

            # حفظ IP وعنوان MAC في جدول ARP
            arp_table[ip] = mac
```

دالة اكتشاف SYN Flood

:def detect_syn_flood(packet)

```
# التأكد أن الحزمة تحتوي على IP وTCP
if not packet.haslayer(IP) or not packet.haslayer(TCP):
    return

# الحصول على معلومات TCP
tcp = packet[TCP]

# التأكد أن الحزمة SYN بدون ACK
if tcp.flags == 'S' or (
    int(tcp.flags) & 0x02 and
    not int(tcp.flags) & 0x10
):

    # الحصول على عنوان IP للمصدر
    source_ip = packet[IP].src

    # الحصول على الوقت الحالي
    now = time.time()
```

```
    # إضافة طلب SYN إلى قائمة المصدر
    syn_requests[source_ip].append(now)

    # حذف الطلبات القديمة
    clean_old(syn_requests, now)

    # إذا وصل عدد SYN إلى الحد المحدد
    if len(syn_requests[source_ip]) >= SYN_LIMIT:

        # إنشاء رسالة تنبيه
        message = (
            f"SYN Flood Attack Detected! "
            f"Source IP={source_ip}, "
            f"SYN Packets Count=
{len(syn_requests[source_ip])} "
            f"within {TIME_WINDOW}s"
        )

        # تسجيل التنبيه
        log_event(message)

        # مسح العدادات بعد تسجيل التنبيه
        syn_requests[source_ip].clear()
```

دالة اكتشاف Port Scanning

:def detect_port_scan(packet)

```
# التأكد أن الحزمة تحتوي على IP
if not packet.haslayer(IP):
    return

# الحصول على IP المصدر
```

```
source_ip = packet[IP].src

# متغير لتخزين منفذ الوجهة
destination_port = None

# إذا كانت الحزمة TCP
if packet.haslayer(TCP):

    # الحصول على منفذ الوجهة
    destination_port = packet[TCP].dport

# إذا كانت الحزمة UDP
elif packet.haslayer(UDP):

    # الحصول على منفذ الوجهة
    destination_port = packet[UDP].dport

# إذا لم يوجد منفذ، إيقاف الدالة
if destination_port is None:
    return

# الحصول على الوقت الحالي
now = time.time()

# حفظ الوقت والمنفذ
port_scans[source_ip].append((now, destination_port))

# حذف البيانات القديمة
clean_old(port_scans, now)

# الحصول على المنافذ المختلفة
unique_ports = {
    item[1] for item in port_scans[source_ip]
}

# إذا تم الوصول إلى عدد المنافذ المحدد
```

```
if len(unique_ports) >= PORT_SCAN_LIMIT:

    # إنشاء رسالة تنبيه
    message = (
        f"Port Scanning Detected! "
        f"Source IP={source_ip}, "
        f"Unique Ports Scanned={len(unique_ports)} "
        f"within {TIME_WINDOW}s"
    )

    # تسجيل التنبيه
    log_event(message)

    # مسح بيانات الفحص بعد تسجيل التنبيه
    port_scans[source_ip].clear()
```

دالة فلترة وتحليل الحزم

:def filter_packet(packet)

```
# البروتوكول الافتراضي
protocol = "Unknown"

# إذا كانت الحزمة ARP
if packet.haslayer(ARP):

    # تحديد البروتوكول
    protocol = "ARP"

# إذا كانت الحزمة TCP
elif packet.haslayer(TCP):

    # تحديد البروتوكول
    protocol = "TCP"
```

```
# إذا كانت الحزمة UDP
elif packet.haslayer(UDP):

    # تحديد البروتوكول
    protocol = "UDP"

# إذا كانت الحزمة ICMP
elif packet.haslayer(ICMP):

    # تحديد البروتوكول
    protocol = "ICMP"

# تجاهل الحزم غير المطلوبة
else:
    return

# عرض معلومات الحزمة
print(
    f"[PACKET] Protocol={protocol} | "
    f"Src={packet[0].src if hasattr(packet[0], 'src')
else 'N/A'}"
)

# فحص ARP Spoofing
detect_arp_spoofing(packet)

# فحص SYN Flood
detect_syn_flood(packet)

# فحص Port Scanning
detect_port_scan(packet)
```

التأكد أن الملف يتم تشغيله مباشرة

:“if name == “main

```
# عرض عنوان الأداة
print("================================================
=")

# عرض اسم المشروع
print(" Network Packet Analyzer & Intrusion Detection ")

# عرض خط فاصل
print("================================================
=")

# إعلام المستخدم ببدء التقاط الحزم
print("Packet capture started...")

# عرض البروتوكولات التي تتم مراقبتها
print("Protocols Monitored: ARP / TCP / UDP / ICMP")

# توضيح طريقة إيقاف البرنامج
print("Press Ctrl+C to stop.\n")

# التقاط الحزم بشكل مستمر وتحليل كل حزمة
sniff(prn=filter_packet, store=False)
```

الوصف

أنشأنا أداة تحليل حزم واكتشاف اختراقات باستخدام Scapy، تلتقط الحزم باستمرار، تراقب ARP/TCP/UDP/ICMP، وتكشف ARP Spoofing وSYN Flood وPort Scanning، ثم تسجل الأحداث المشبوهة في ملف وتعرض تنبيهًا فوريًا.

امن شبكات

توثيق المشاريع والتطبيقات العملية

المدونة حول الأسئلة المتكررة المؤلفون

الفعاليات متجر الأنماط القوالب

Twenty Twenty-Five

صُمم باستخدام WordPress

الرئيسية

أنشطة ومشاريع أمن الشبكات

المستوى الثالث

م. فؤاد العداهي

توثيق الأنشطة والتطبيقات العملية والأوامر ونتائج الاختبارات.

يشمل التوثيق:

- تأمين الراوتر R1
- تأمين السويتش SwitchL2-1
- إعداد ASA
- إعداد VPN Site-to-Site
- أداة تحليل حزم الشبكة واكتشاف الاختراقات
- أداة تعداد النطاقات والخدمات
- أداة فحص ثغرات الويب

امن شبكات

توثيق المشاريع والتطبيقات العملية

المدونة حول الأسئلة المتكررة المؤلفون

الفعاليات متجر الأنماط القوالب

Twenty Twenty-Five

صُمم باستخدام WordPress

اعداد ASA

السؤال الأول : إعداد ASA لتوزيع DHCP وتوجيه الإنترنت

التدريب:

لديك في GNS3 الطوبولوجيا التالية:

- ASA موصول بـ Cloud خارجياً و Switch داخلياً
- السويتش موصول بـ PC1 و PC2
- OPNsense هو بوابة الإنترنت بعنوان 192.168.100.2

المطلوب:

1. قم بتكوين الواجهة الخارجية (Outside) لـ ASA لتحصل على عنوان IP من DHCP
2. قم بتكوين الواجهة الداخلية (Inside) بعنوان 192.168.10.1/24
3. قم بإعداد خدمة DHCP على ASA لتوزيع العناوين من النطاق 192.168.10.10 إلى 192.168.10.50 و DNS 8.8.8.8
4. أضف مساراً افتراضياً يوجه الحركة إلى OPNsense
5. فعل NAT (PAT) لإخفاء الشبكة الداخلية خلف عنوان الواجهة الخارجية.
6. اسمح بحركة ICMP من الداخل إلى الخارج.

اكتب أوامر العرض للتحقق من:

- حالة الواجهات.
- جدول التوجيه.
- عناوين DHCP الموزعة.
- ترجمة العناوين (NAT)

إعداد ASA لتوزيع DHCP وتوجيه الإنترنت

تم إعداد الواجهة الخارجية والداخلية، وتفعيل DHCP للشبكة الداخلية، وإضافة المسار الافتراضي، وتفعيل NAT/PAT، والسماح بحركة ICMP، مع تنفيذ أوامر التحقق من الواجهات والتوجيه وDHCP وNAT.

```
enable
configure terminal

!
================================================================
! 1. إعداد الواجهة الخارجية (Outside) للحصول على IP عبر DHCP
!
================================================================
interface GigabitEthernet0/0
 nameif outside
 security-level 0
 ip address dhcp setroute
 no shutdown
 exit
! ملاحظة: خيار setroute يُضيف المسار الافتراضي من خادم DHCP تلقائياً إن وُجد

!
================================================================
! 2. إعداد الواجهة الداخلية (Inside)
!
================================================================
```

```
interface GigabitEthernet0/1
nameif inside
security-level 100
ip address 192.168.10.1 255.255.255.0
no shutdown
exit

!
============================================================
! 3. إعداد خدمة DHCP Server لتوزيع العناوين على الشبكة الداخلية
!
============================================================
dhcpd address 192.168.10.10-192.168.10.50 inside
dhcpd dns 8.8.8.8 inside
dhcpd enable inside

!
============================================================
! 4. إضافة مسار افتراضي (Default Route) يوجه إلى بوابة OPNsense
!
============================================================
route outside 0.0.0.0 0.0.0.0 192.168.100.2

!
============================================================
! 5. تفعيل Dynamic PAT (Port Address Translation)
!
============================================================
object network OBJ_INSIDE_NET
subnet 192.168.10.0 255.255.255.0
```

```
nat (inside,outside) dynamic interface
exit

!
============================================================
! 6. السماح بحركة مرور ICMP (Ping) والرد عليها من الداخل للخارج
!
============================================================
! السماح لجميع حزم الـ ICMP بالمرور عبر فحص الحركة التفاعلي (Stateful Inspection)
policy-map global_policy
class inspection_default
inspect icmp
exit
exit

end
```

العرض

لعرض حالة الواجهات والعناوين المسندة:

```
show interface ip brief
```

لعرض جدول التوجيه والتأكد من وجود المسار الافتراضي نحو OPNsense

```
show route
```

لعرض عناوين IP الموزعة حالياً على الأجهزة بواسطة DHCP:

```
show dhcpd binding
```

لعرض جدول ترجمة العناوين (NAT/PAT Translations)

show xlate

امن شبكات

توثيق المشاريع والتطبيقات العملية

المدونة حول الأسئلة المتكررة المؤلفون

الفعاليات متجر الأنماط القوالب

Twenty Twenty-Five

صُمم باستخدام WordPress